

МЕТОДИЧКА ПО ДИСЦИПЛИНЕ «СИСТЕМЫ МОНИТОРИНГА И УПРАВЛЕНИЯ ИНЦИДЕНТАМИ ИНФОРМАЦИОННОЙ БЕЗОПАСНОСТИ» (СМИУКИ / СМиУИИБ)

Полное практическое пособие для подготовки к зачёту с нуля: вводная теория, развёрнутые ответы на все 28 вопросов и краткие шпаргалки для повторения.

Как пользоваться этой методичкой

Документ состоит из трёх частей. **Часть I «Теория»** — это фундамент: она вводит вас в предмет, объясняет базовые понятия, логику дисциплины и связи между темами. Прочитайте её первой, даже если знаний почти нет: после неё все вопросы будут восприниматься осмысленно, а не как набор разрозненных терминов. **Часть II «Развёрнутые ответы»** — это полные ответы на каждый из 28 вопросов; они написаны «от простого к сложному», их можно читать, пересказывать своими словами и при необходимости использовать как опору на зачёте. **Часть III «Краткое саммари»** — это сжатые шпаргалки по каждому вопросу: их удобно перечитать вечером перед сном или утром перед зачётом, чтобы быстро освежить и закрепить материал.

Совет по запоминанию: сначала поймите **логику** (зачем нужна тема, какую проблему решает), затем заучивайте **термины и аббревиатуры**. В этой дисциплине очень много англоязычных сокращений (SIEM, SOAR, XDR, IDS/IPS, IoC, APT, ГосСОПКА) — выпишите их на отдельный лист и повторяйте, потому что преподаватель почти наверняка будет спрашивать расшифровку и отличия похожих систем друг от друга.

ЧАСТЬ I. ТЕОРИЯ: ВВЕДЕНИЕ В ПРЕДМЕТ

1. О чём вообще эта дисциплина и зачем она нужна

Любая современная организация — банк, завод, больница, госорган — работает на информационных системах: серверах, рабочих станциях, сетевом оборудовании, базах данных. Эти системы постоянно атакуют: по оценке Cybersecurity Ventures мировой ущерб от киберпреступности измеряется десятками триллионов долларов в год и продолжает расти. Поставить «стену» (антивирус и межсетевой экран) и считать себя защищённым уже недостаточно: атаки стали сложными, многоэтапными и скрытными. Поэтому защита строится по принципу **«предполагай взлом» (assume breach)**: исходим из того, что рано или поздно злоумышленник проникнет внутрь, и значит нужно уметь **вовремя это заметить и быстро отреагировать**.

Именно об этом дисциплина. Она делится на две тесно связанные половины, зашитые прямо в её название:

- **Мониторинг ИБ** — это «глаза и уши» системы защиты: постоянное наблюдение за событиями безопасности, чтобы обнаруживать нарушения, угрозы и уязвимости. Мониторинг отвечает на вопрос «**что происходит и не происходит ли что-то плохое прямо сейчас?**».
- **Управление инцидентами (incident management / response)** — это то, что делают, когда плохое уже обнаружено: организованный процесс обнаружения, реагирования, ликвидации последствий и извлечения уроков. Управление инцидентами отвечает на вопрос «**обнаружили атаку — что теперь делать, по шагам?**».

Грубая аналогия: мониторинг — это система видеонаблюдения и сигнализация в здании; управление инцидентами — это регламент действий охраны и сотрудников, когда сигнализация сработала (кто звонит, кто перекрывает выходы, кто пишет рапорт, как потом меняют замки, чтобы это не повторилось).

2. Ключевая «пирамида» понятий: событие → уязвимость/угроза → атака → инцидент

Это самая важная цепочка во всей дисциплине. Если вы её поймёте, половина вопросов «раскроется» сама собой.

- **Событие безопасности** — любое зафиксированное состояние системы или сети, которое **может** быть значимо для безопасности: вход пользователя, неудачная попытка входа, запуск программы, открытие сетевого соединения, срабатывание антивируса. Событий — миллионы в день, и большинство из них совершенно безобидны. Событие — это ещё **не** проблема, это просто «факт, записанный в журнал».
- **Уязвимость** — недостаток (слабость) системы, который создаёт условия для реализации угрозы. Например, непропатченная программа, слабый пароль, открытый наружу порт. Уязвимость — это «незапертая дверь».
- **Угроза** — совокупность условий и факторов, создающих потенциальную или реальную опасность нарушения безопасности. Угроза — это «существование вора, который может войти в незапертую дверь».
- **Компьютерная атака** — целенаправленное вредоносное (противоправное) воздействие на информационные ресурсы с использованием программных/программно-аппаратных средств. Атака — это «вор реально подошёл к двери и дёргает ручку».
- **Компьютерный инцидент** — факт нарушения и (или) прекращения работы объекта или нарушения безопасности обрабатываемой информации, в том числе произошедший в результате компьютерной атаки. Инцидент — это «вор вошёл и что-то украл или сломал», то есть **состоявшееся** нарушение.

Связь простыми словами: **угроза эксплуатирует уязвимость через атаку, и если атака удалась — возникает инцидент**. Задача мониторинга — увидеть в потоке миллионов событий те немногие, которые складываются в признаки атаки и инцидента. Задача управления инцидентами — правильно отработать инцидент.

3. Почему нельзя просто «смотреть в логи» — проблема объёма и контекста

Каждый сервер, межсетевой экран, антивирус и приложение пишут свои **журналы (логи)**. Проблема в том, что: (1) их слишком много — вручную не просмотреть; (2) форматы у всех разные (один firewall пишет «deny», другой «drop», третий «discard» про одно и то же); (3) одно событие почти никогда не говорит об атаке. Классический пример: одна запись «login failed» (неудачный вход) ничего не значит — человек опечатался. Но **пять таких записей за минуту по одной учётке** — это уже признак подбора пароля (brute-force).

Чтобы справиться с этим, придумали целый «зоопарк» специальных систем, и их изучение — стержень дисциплины:

- **IDS/IPS** — обнаружение/предотвращение сетевых вторжений (анализ трафика).
- **SIEM** — сбор, нормализация и **корреляция** событий из всех источников; «мозг» мониторинга, который складывает разрозненные события в инциденты.
- **SOAR/IRP** — автоматизация и оркестрация реагирования по сценариям («плейбукам»).
- **EDR/XDR** — обнаружение и реагирование на конечных точках (EDR) и расширенно по всей инфраструктуре (XDR).
- **Threat Intelligence (TI)** — киберразведка: знания об актуальных угрозах, группировках и **индикаторах компрометации (IoC)**, которыми «подкармливают» все остальные системы.
- **Песочницы (sandbox), NTA/NDR, DLP, сканеры уязвимостей** — вспомогательные источники и средства.

Над всем этим в крупной организации стоит **SOC (Security Operations Center)** — центр мониторинга и реагирования, где люди (аналитики) и технологии (SIEM, SOAR, TI) работают вместе круглосуточно.

4. Эволюция средств: как одно выросло из другого

Запомнить системы проще, если понять, что они появлялись эволюционно, закрывая недостатки предыдущих:

- Сначала был **межсетевой экран (firewall)** — фильтрует трафик по адресам/портам. Недостаток: пропускает вредоносный трафик, если он формально разрешён правилами.

- Поэтому добавили **IDS** (только обнаруживает и оповещает) и **IPS** (обнаруживает и автоматически блокирует). Сегодня IPS обычно входит в **межсетевой экран нового поколения (NGFW)**.
- События от firewall, IDS, антивирусов и т.д. нужно было собрать вместе — так из слияния **SIM** (анализ накопленной информации) и **SEM** (обработка событий в реальном времени) родился **SIEM**.
- SIEM хорошо собирает и коррелирует, но **сам не реагирует** и заваливает аналитиков оповещениями. Чтобы автоматизировать реагирование, появился **SOAR** (оркестрация + автоматизация + плейбуки).
- Параллельно на конечных точках антивирус эволюционировал в **EDR** (поведенческий анализ + реагирование на хостах), а EDR, объединившись с сетью, почтой, облаком — в **XDR** (расширенное обнаружение и реагирование «из коробки»).
- Чтобы все эти системы знали, **что именно** искать, их питает **Threat Intelligence** — индикаторы компрометации и матрица **MITRE ATT&CK** (база тактик и техник злоумышленников).

Эту «лестницу эволюции» очень любят на зачётах: умение объяснить, чем SIEM отличается от SOAR, EDR от XDR, IDS от IPS — почти гарантированный вопрос.

5. Как атакуют: модели Cyber Kill Chain и MITRE ATT&CK

Чтобы защищаться, надо понимать логику нападения. Сложная атака — это не один удар, а **последовательность этапов**. Две главные модели:

- **Cyber Kill Chain (Lockheed Martin)** — описывает атаку как «цепочку поражения» из 7 последовательных этапов: разведка → вооружение → доставка → эксплуатация → установка → управление (C2) → действия по цели. Главная идея: **если разорвать цепочку на любом звене — атака сорвана**, поэтому защита должна перехватывать атаку как можно раньше.
- **MITRE ATT&CK** — огромная матрица-база знаний реальных **тактик** (зачем, цели злоумышленника) и **техник** (как именно он это делает). В отличие от линейной Kill Chain, ATT&CK — это «энциклопедия приёмов», на которую опираются TI, SIEM-правила, EDR/XDR и аналитики SOC.

Параллельно вводится понятие **APT (Advanced Persistent Threat)** — сложная, развитая и устойчивая целевая атака, которую часто ведут хорошо финансируемые группировки (в т.ч. спецслужбы), скрытно и долго. Классические примеры — черви Stuxnet и Flame против инфраструктуры Ирана. Именно против APT обычные средства защиты бессильны — нужны SIEM, TI, EDR/XDR и SOC.

6. Куда смотреть: артефакты в Windows и Linux

Когда инцидент обнаружен, аналитик идёт «копать» на конкретные машины и ищет **следы (артефакты)** атаки в операционной системе. Поэтому в дисциплине отдельный блок —

особенности расследования в **Windows** (журнал аудита / Event Log, системный реестр, процессы, повышение привилегий) и в **Linux** (файловая система, права доступа, логи в /var/log, подсистема аудита auditd, история команд). Это «цифровая криминалистика» (forensics) на уровне, достаточном для распознавания признаков компрометации.

7. Правовое поле России: КИИ, 187-ФЗ и ГосСОПКА

В России мониторинг и управление инцидентами — это не только техника, но и **закон**.
Ключевые элементы:

- **187-ФЗ «О безопасности критической информационной инфраструктуры (КИИ)»** (2017) — обязывает значимые объекты (банки, энергетику, связь, здравоохранение, госорганы и т.д.) защищаться и сообщать об инцидентах.
- **ГосСОПКА** — Государственная система обнаружения, предупреждения и ликвидации последствий компьютерных атак: общенациональная сеть центров мониторинга во главе с **НКЦКИ** (Национальный координационный центр по компьютерным инцидентам), куда субъекты КИИ обязаны сообщать об инцидентах.
- **Стандарты ГОСТ Р серии 597xx** (59709–59712, 2022 г.) — задают единые термины и порядок управления компьютерными инцидентами; **приказы ФСТЭК и ФСБ** — конкретные требования к защите и к техническим средствам.

Эту часть тоже спрашивают: важно знать «кто за что отвечает» (ФСТЭК — требования к защите КИИ, ФСБ/НКЦКИ — ГосСОПКА и реагирование) и сроки уведомления об инцидентах.

8. Краткий глоссарий ключевых аббревиатур (выучить обязательно)

- **ИБ** — информационная безопасность; **И(А)С** — информационная (автоматизированная) система; **СЗИ** — средства/система защиты информации; **СОА** — система обнаружения атак.
- **IDS / IPS** — Intrusion Detection / Prevention System (обнаружение / предотвращение вторжений).
- **NGFW** — Next Generation Firewall (межсетевой экран нового поколения); **WAF** — Web Application Firewall.
- **SIEM** — Security Information and Event Management (сбор и корреляция событий).
- **SOAR** — Security Orchestration, Automation and Response (оркестрация и автоматизация реагирования); **IRP** — Incident Response Platform.
- **EDR / XDR** — Endpoint / Extended Detection and Response.
- **UEBA** — User and Entity Behavior Analytics (анализ поведения); **NTA/NDR** — Network Traffic Analysis / Network Detection and Response.
- **TI** — Threat Intelligence (киберразведка); **TIP** — Threat Intelligence Platform; **IoC** — Indicator of Compromise (индикатор компрометации).

- **APT** — Advanced Persistent Threat (целевая устойчивая угроза); **C2/C&C** — Command and Control (центр управления).
- **SOC** — Security Operations Center; **MTTD/MTTR** — среднее время обнаружения / реагирования.
- **CVE / CWE / CVSS / NVD / CPE** — реестр уязвимостей / словарь типов слабостей / система оценки опасности / нац. база США / идентификация платформ.
- **КИИ / ЗОКИИ** — критическая информационная инфраструктура / значимый объект КИИ; ГосСОПКА, НКЦКИ, ФСТЭК, ФСБ.

ЧАСТЬ II. РАЗВЁРНУТЫЕ ОТВЕТЫ НА ВОПРОСЫ

Вопрос 1. Нормативно-методическое обеспечение управления компьютерными инцидентами: нормативные правовые акты, национальные стандарты

Суть вопроса: какие законы, подзаконные акты и стандарты в России регулируют тему мониторинга ИБ и управления компьютерными инцидентами. Отвечать удобно «сверху вниз»: от федеральных законов к приказам регуляторов и далее к ГОСТам.

1) Федеральные законы (верхний уровень).

- **№ 149-ФЗ «Об информации, информационных технологиях и о защите информации»** (2006) — базовый закон, вводит понятия информации, её защиты, обязанности обладателя информации.
- **№ 187-ФЗ «О безопасности критической информационной инфраструктуры РФ»** (2017, вступил в силу 01.01.2018) — ключевой закон по теме. Он вводит понятия КИИ, субъекта и объекта КИИ, обязывает категоризовать объекты, защищать их и **информировать о компьютерных инцидентах** уполномоченный орган (ГосСОПКА/НКЦКИ). Именно из 187-ФЗ «растёт» вся практика управления инцидентами в значимых системах.
- **№ 152-ФЗ «О персональных данных»** — смежный закон, требует защищать ПДн и реагировать на их утечки.

2) Указы Президента.

- **Указ № 31с (2013)** — о создании ГосСОПКА.
- **Указ № 620 (2017)** — утверждает Положение о ГосСОПКА и закрепляет роль ФСБ как уполномоченного органа.
- **Указ № 250 (2022)** — о дополнительных мерах по обеспечению ИБ: требует от организаций назначить ответственного зам. руководителя за ИБ, создать профильные подразделения, разрешает привлекать лицензиатов.

3) Подзаконные акты регуляторов (приказы ФСТЭК и ФСБ). Полномочия разделены: **ФСТЭК России** отвечает за **требования к защите** информации и объектов КИИ, **ФСБ России (НКЦКИ)** — за **ГосСОПКА и реагирование на инциденты**.

- Приказы ФСТЭК № 235 (требования к системам безопасности значимых объектов КИИ), № 239 (меры по обеспечению безопасности ЗОКИИ), № 31 (АСУ ТП), № 17 (ГИС), № 21 (ПДн).
- Приказы ФСБ по ГосСОПКА: № 367 и № 368 (2018) — перечень и порядок представления сведений об инцидентах, регламент обмена; № 196 (2019) — **требования к техническим средствам ГосСОПКА**; № 281 и № 282 (2019) — порядок

установки средств и информирования. (Часть приказов в 2024–2025 гг. пересматривается, но логика сохраняется.)

4) Национальные стандарты (ГОСТ Р). Профильная серия по управлению инцидентами, утверждённая в 2022 г.:

- **ГОСТ Р 59709-2022** — «Управление компьютерными инцидентами. **Термины и определения**».
- **ГОСТ Р 59710-2022** — «**Общие положения**» (вводит стадии управления инцидентами).
- **ГОСТ Р 59711-2022** — «**Организация деятельности** по управлению компьютерными инцидентами».
- **ГОСТ Р 59712-2022** — «**Руководство по реагированию** на компьютерные инциденты».

Сопутствующие: **ГОСТ Р 50922-2006** (защита информации, основные термины), **ГОСТ Р 53114-2008** (обеспечение ИБ в организации, термины), **ГОСТ Р 59547-2021** (мониторинг ИБ, общие положения), серия **ГОСТ Р ИСО/МЭК 27000** (СМИБ; в т.ч. 27035 — управление инцидентами ИБ), **ГОСТ Р 56546** (уязвимости, классификация).

Вывод одной фразой: обеспечение строится по вертикали «закон (149-ФЗ, 187-ФЗ) → указы Президента (620, 250) → приказы ФСТЭК (защита) и ФСБ/НКЦКИ (ГосСОПКА) → национальные стандарты ГОСТ Р 597xx (термины и порядок)».

Вопрос 2. Основные понятия и определения

Здесь нужно чётко, по-словарному, дать определения. Привожу их с короткими пояснениями.

- **Мониторинг ИБ** — процесс постоянного наблюдения и анализа результатов регистрации событий безопасности с целью выявления нарушений безопасности информации, угроз и уязвимостей в И(А)С. Коротко: непрерывное наблюдение, чтобы вовремя заметить плохое.
- **Объект мониторинга** — то, за чем наблюдают: автоматизированные рабочие места (АРМ), серверное оборудование, телекоммуникационное оборудование, технологическое/производственное оборудование (исполнительные устройства), средства защиты информации.
- **Событие безопасности (ИБ)** — зафиксированное состояние И(А)С, сетевого/прикладного сервиса или сети, указывающее на возможное нарушение безопасности информации, сбой СЗИ или ситуацию, которая может быть значимой для ИБ. Коротко: «факт из журнала», который, возможно, важен.
- **Уязвимость** — недостаток (слабость) И(А)С, создающий потенциальные или реальные условия для реализации угроз безопасности информации. Коротко: «дыра» в защите.
- **Описание уязвимости** — формализованные сведения об уязвимости: идентификатор (например, CVE-ID), затронутый продукт и версии (CPE), тип слабости (CWE), оценка опасности (CVSS), способы устранения. Используется в реестрах CVE/NVD/БДУ ФСТЭК.

- **Угроза безопасности информации** — совокупность условий и факторов, создающих потенциальную или реально существующую опасность нарушения безопасности информации.
- **Меры защиты информации (меры ЗИ)** — совокупность действий, направленных на разработку и (или) практическое применение способов и средств обеспечения ИБ (организационные и технические меры).
- **Компенсирующие меры** — меры, применяемые вместо базовых (предусмотренных требованиями) мер, когда последние технически невозможно или нецелесообразно реализовать; компенсирующие меры должны обеспечивать **эквивалентный** уровень защиты и обосновываются в модели угроз.
- **Компьютерная атака** — целенаправленное несанкционированное воздействие на информационные ресурсы и И(А)С с использованием программных или программно-аппаратных средств с целью нарушения безопасности информации (нарушения конфиденциальности, целостности, доступности).
- **Компьютерный инцидент** — факт нарушения и (или) прекращения функционирования объекта (КИИ, И(А)С) и (или) нарушения безопасности обрабатываемой информации, в том числе произошедший в результате компьютерной атаки.
- **Управление компьютерным инцидентом (incident management)** — комплекс мероприятий по обнаружению, регистрации, реагированию на инциденты, ликвидации их последствий и анализу результатов с целью предотвращения повторения.

Дополнительно полезно знать пары-«операции» мониторинга: **фильтрация** (выборка нужных событий по правилам), **нормализация** (приведение событий разных источников к единому формату), **агрегация** (объединение однородных событий), **корреляция** (выявление логически связанной последовательности разнородных событий, значимой для обнаружения нарушения).

Вопрос 3. Мониторинг ИБ: задачи, объекты, уровни, свойства

Определение (повторяем): мониторинг ИБ — процесс постоянного наблюдения и анализа результатов регистрации событий безопасности с целью выявления нарушений, угроз и уязвимостей в И(А)С.

Мониторинг включает четыре группы мероприятий: (1) контроль за событиями безопасности и действиями пользователей; (2) контроль (анализ) защищённости информации; (3) анализ и оценка функционирования системы защиты информации; (4) периодический анализ изменения угроз безопасности.

Объекты мониторинга: автоматизированные рабочие места; серверное оборудование; телекоммуникационное оборудование; технологическое и (или) производственное оборудование (исполнительные устройства); средства защиты информации.

Уровни мониторинга (как «слои» обработки данных):

1. **Уровень источников данных** — где рождаются события (ОС, СЗИ, сетевое оборудование, приложения).
2. **Уровень сбора данных** — агенты/коллекторы собирают события и передают дальше.
3. **Уровень хранения и обработки данных** — нормализация, фильтрация, агрегация, корреляция, хранение (ядро SIEM).
4. **Уровень представления информации потребителям** — дашборды, отчёты, оповещения для аналитиков и руководства.

Задачи мониторинга (по группам мероприятий, кратко):

- ***Контроль событий и действий пользователей:*** сбор данных о событиях из разных источников; нормализация, фильтрация, агрегация; корреляция для выявления нарушений; сопоставление событий с потоками данных об угрозах (индикаторами компрометации); учёт и анализ действий пользователей и администраторов; сопоставление событий с результатами анализа уязвимостей; выявление нарушений и информирование ответственных лиц.
- ***Контроль защищённости:*** поиск уязвимостей и подготовка отчётов с рекомендациями; контроль установки обновлений ПО (в т.ч. СЗИ); инвентаризация технических средств и ПО; контроль соответствия настроек политикам безопасности; контроль потоков информации.
- ***Анализ функционирования СЗИ:*** контроль работоспособности и неотключения СЗИ; проверка соответствия среды функционирования требованиям документации; информирование о сбоях и отказах.
- ***Анализ изменения угроз:*** получение данных о новых угрозах из доступных источников; оценка их актуальности для системы и выработка рекомендаций по мерам защиты.

Свойства (требования к) мониторинга: непрерывность (24/7); полнота охвата (внешний и внутренний периметр, все значимые объекты); достоверность и информативность источников; своевременность (близко к реальному времени); масштабируемость; управляемость (настраиваемые правила); измеримость (метрики, например MTTR/MTTD). Эти свойства определяют, будет ли мониторинг реально эффективным или превратится в «чёрный ящик».

Вопрос 4. События безопасности, регистрируемые СЗИ (средствами защиты информации)

Идея вопроса: перечислить, какие события безопасности порождают именно **средства защиты** (а не сами прикладные системы). СЗИ — это специализированные продукты ИБ; их события самые «говорящие» для аналитика.

Источники-СЗИ и их характерные события:

- **Межсетевые экраны (firewall/NGFW):** разрешение/блокировка сетевых соединений (allow/deny/drop), срабатывание правил фильтрации, попытки доступа к запрещённым ресурсам, изменение конфигурации МЭ.
- **IDS/IPS (системы обнаружения/предотвращения вторжений):** обнаружение сигнатур атак, аномалий трафика, сканирование портов, эксплойты, обращения к C2/бот-сетям; для IPS — факты блокировки/сброса соединений.
- **Антивирусы и средства защиты конечных точек (EPP/EDR):** обнаружение и удаление вредоносного ПО, помещение в карантин, блокировка запуска, события о работоспособности и актуальности баз, изменение политик.
- **Средства контроля доступа и аутентификации (IdM/PAM, контроллеры домена):** успешные и неуспешные входы, блокировка учётных записей, использование привилегий, изменение прав.
- **DLP-системы:** попытки утечки конфиденциальной информации (отправка по почте, копирование на USB, печать), нарушение политик.
- **Средства контроля устройств и портов:** подключение/отключение съёмных носителей, попытки использования запрещённых устройств.
- **Сканеры уязвимостей:** обнаруженные уязвимости, изменения в составе ПО, результаты инвентаризации.
- **Средства криптозащиты (СКЗИ), VPN-шлюзы:** установление/разрыв защищённых соединений, ошибки аутентификации, события целостности.
- **WAF (межсетевые экраны веб-приложений):** атаки на веб (SQL-инъекции, XSS), блокировки запросов.

Что важно подчеркнуть на зачёте: события от СЗИ ценны тем, что они уже «отфильтрованы» с точки зрения безопасности — это не просто «технический шум», а сигналы о потенциальных угрозах. Именно их в первую очередь собирают в SIEM и коррелируют между собой.

Вопрос 5. События безопасности, регистрируемые средствами И(А)С (информационной/автоматизированной системы)

Отличие от вопроса 4: здесь речь о событиях, которые порождают **штатные средства самой системы** — операционные системы, СУБД, прикладное и сетевое ПО (а не специализированные СЗИ). Это «встроенные» механизмы регистрации (аудита).

Источники И(А)С и их события:

- **Операционные системы (Windows, Linux):** вход/выход пользователей, успешные/неуспешные попытки аутентификации, создание/удаление учётных записей, изменение прав и групп, запуск процессов, доступ к файлам и объектам, изменение системных настроек, очистка журналов аудита, установка/удаление ПО и служб. В Windows это журналы Security/System/Application (Event Log), в Linux — /var/log и подсистема auditd.

- **СУБД (базы данных):** подключения к БД, выполнение запросов, изменение схемы и прав, экспорт больших объёмов данных, неуспешные авторизации.
- **Веб- и прикладные серверы:** обращения к ресурсам (логи доступа), коды ответов (ошибки 4xx/5xx), аутентификация пользователей в приложении, административные действия.
- **Сетевое активное оборудование (маршрутизаторы, коммутаторы):** изменения конфигурации, доступ к управлению устройством, счётчики и аномалии трафика (в т.ч. через NetFlow), события протоколов маршрутизации.
- **Службы каталогов (Active Directory):** аутентификация, выдача билетов Kerberos, изменения объектов каталога, репликация.
- **Системы виртуализации и облака:** создание/удаление VM, доступ к гипервизору, изменения конфигурации.

Ключевая мысль: события И(А)С — это «сырьё» о нормальной и аномальной работе самой инфраструктуры. По отдельности они часто незаметны, но в корреляции с событиями СЗИ (вопрос 4) дают полную картину. Например, событие ОС «создан новый администратор» + событие AD «вход с нетипичного хоста» + событие firewall «исходящее соединение на неизвестный IP» — вместе складываются в картину компрометации, хотя по отдельности каждое выглядит безобидно.

Вопрос 6. Управление компьютерными инцидентами: стадии, содержание и задачи каждой стадии

Это один из центральных вопросов. Опираемся на **ГОСТ Р 59710-2022 / 59712-2022**.

Управление инцидентами — это структурированный, циклический процесс из **четырёх стадий**.

Стадия 1. Организация деятельности по управлению компьютерными инцидентами (подготовка).

Это всё, что делается **заранее, до инцидента**, чтобы быть готовым. Содержание и задачи: назначение ответственных и формирование группы реагирования (команды); распределение ролей и полномочий; разработка внутренних документов — политики, регламентов, **плана реагирования** и инструкций (плейбуков); определение порядка взаимодействия с ГосСОПКА/НКЦКИ и внешними сторонами; обеспечение необходимыми техническими средствами (SIEM, EDR/XDR, средства сбора артефактов); обучение персонала и проведение тренировок (киберучений); определение критериев категорирования инцидентов и приоритетов. Главная идея: «кто к инциденту не готовится — тот к нему опоздает».

Стадия 2. Обнаружение и регистрация компьютерных инцидентов.

Содержит два подэтапа: (а) **регистрация признаков** возможного возникновения инцидентов — фиксация подозрительных событий (срабатывания СЗИ, оповещения SIEM, сообщения пользователей, данные TI/индикаторы компрометации); (б) **подтверждение инцидента** — анализ признаков, отсеивание ложных срабатываний и принятие решения, что это действительно инцидент. Задачи: сбор и нормализация событий, корреляция, первичная оценка, присвоение инциденту идентификатора и категории, занесение в журнал учёта инцидентов.

Стадия 3. Реагирование на компьютерные инциденты.

Самая «активная» стадия. По ГОСТ Р 59712 включает последовательность шагов:

5. **Определение элементов инфраструктуры, вовлечённых в инцидент** (какие хосты, учётные записи, сервисы затронуты — определение масштаба).
6. **Локализация инцидента** — сдерживание (containment): изоляция заражённых узлов, блокировка учёток и сетевых соединений, чтобы не дать атаке распространиться.
7. **Определение (выявление) последствий** — что именно пострадало (данные, сервисы, репутация).
8. **Ликвидация последствий** — удаление вредоносного ПО, закрытие уязвимостей, восстановление систем из резервных копий, смена скомпрометированных паролей/ключей.
9. **Закрытие инцидента** — подтверждение, что угроза устранена и работа восстановлена.

10. **Фиксация материалов, относящихся к инциденту** — сбор и сохранение доказательной базы (артефакты, логи, образы) для последующего анализа и возможных разбирательств.
11. **Установление причин и условий возникновения инцидента** — как и почему атака удалась.

Стадия 4. Анализ результатов деятельности по управлению инцидентами (постинцидентный анализ, «уроки»).

Содержание и задачи: (а) получение и накопление опыта по результатам управления инцидентами; (б) разработка рекомендаций по устранению причин и условий, способствовавших инциденту (улучшение конфигураций, политик, обучения); (в) оценка результатов реагирования и его эффективности (метрики MTTD/MTTR, что сработало, что нет). Цель — «учиться на инцидентах», чтобы они не повторялись; результаты возвращаются в стадию 1, замыкая цикл.

Главная мысль: процесс **циклический** (подготовка → обнаружение → реагирование → анализ → снова подготовка). Хорошо звучит на зачёте аналогия с международным стандартом ISO/IEC 27035 и циклом PDCA (планируй–делай–проверяй–улучшай).

Вопрос 7. Мероприятия по управлению компьютерными инцидентами

Здесь нужно перечислить **конкретные мероприятия** (действия), наполняющие стадии из вопроса 6. Удобно сгруппировать их.

Подготовительные (организационные) мероприятия:

- создание и поддержание группы (команды) реагирования на инциденты;
- разработка и актуализация политики ИБ, регламентов, плана реагирования и плейбуков;
- категорирование объектов и определение критериев приоритизации инцидентов;
- внедрение и настройка средств мониторинга (SIEM, IDS/IPS, EDR/XDR, TI);
- подключение к ГосСОПКА/НКЦКИ и согласование порядка информирования;
- обучение сотрудников, киберучения, тестирование плана.

Мероприятия обнаружения и регистрации:

- непрерывный сбор и корреляция событий безопасности;
- мониторинг оповещений СЗИ и сообщений пользователей;
- сопоставление с индикаторами компрометации (IoC) из TI;
- подтверждение/отсев инцидентов, их регистрация и категорирование.

Мероприятия реагирования:

- определение масштаба (затронутые активы и учётные записи);
- локализация/сдерживание (изоляция узлов, блокировка учётки и соединений);

- сбор и сохранение цифровых доказательств (артефактов, образов, логов);
- ликвидация (удаление ВПО, патчинг, восстановление из бэкапов, смена паролей/ключей);
- информирование руководства, при необходимости — НКЦКИ (в установленные сроки), при признаках преступления — правоохранительных органов;
- закрытие инцидента.

Мероприятия анализа результатов:

- разбор инцидента (root cause analysis), оформление отчёта;
- обновление правил корреляции, сигнатур, плейбуков, IoC;
- выработка и внедрение рекомендаций по устранению причин;
- расчёт метрик эффективности и корректировка процессов.

Связующие (сквозные) мероприятия: документирование всех действий, обмен информацией с ГосСОПКА и партнёрами, обновление базы знаний об угрозах.

Вопрос 8. План реагирования на компьютерные инциденты (IRP — Incident Response Plan)

Что это: заранее разработанный документ, описывающий, **кто, что, когда и как** делает при возникновении инцидента. План превращает хаотичные действия «по наитию» в управляемый, отрететированный процесс. Разрабатывается на стадии подготовки (вопрос 6, стадия 1).

Зачем нужен: во время инцидента нет времени думать «что делать» — счёт идёт на минуты. План снижает время реакции, исключает ошибки от паники, обеспечивает юридическую корректность (сохранение доказательств) и выполнение требований закона (своевременное уведомление НКЦКИ).

Типовая структура (содержание) плана:

12. **Назначение, область действия и термины** — на какие системы распространяется, ключевые определения.
13. **Роли и ответственность** — состав группы реагирования, контакты, кто принимает решения, кто общается с регуляторами/СМИ, матрица эскалации.
14. **Классификация и категорирование инцидентов** — типы инцидентов и критерии их приоритета/критичности.
15. **Порядок обнаружения и регистрации** — источники сигналов, как фиксируется инцидент.
16. **Процедуры реагирования по этапам** — сдерживание, устранение, восстановление; часто оформляются как **плейбуки** под конкретные типы (заражение ВПО, фишинг, DDoS, утечка данных, шифровальщик и т.п.).

17. **Порядок коммуникаций и уведомлений** — внутренние оповещения, информирование НКЦКИ/ГосСОПКА в установленные сроки, при необходимости — правоохранительных органов, клиентов, регуляторов.
18. **Порядок сбора и хранения доказательств** — как корректно собирать артефакты, чтобы они имели юридическую силу.
19. **Восстановление и закрытие** — критерии возврата к нормальной работе.
20. **Постинцидентный анализ и обновление плана** — порядок разбора и внесения улучшений.
21. **Приложения** — контакты, шаблоны отчётов, чек-листы, схемы сети, перечень критичных активов.

Важно: план — «живой» документ; его регулярно тестируют (киберучения, table-top exercises) и обновляют после каждого крупного инцидента и изменения инфраструктуры. Автоматизация исполнения плейбуков — задача систем класса **SOAR/IRP**.

Вопрос 9. Определение очередности (приоритета) реагирования на компьютерные инциденты

Проблема: инцидентов может быть много одновременно, а ресурсы (люди, время) ограничены. Нужно решить, **какой инцидент отрабатывать первым**. Это и есть приоритизация (триаж).

Принцип: приоритет инцидента определяется сочетанием **критичности (значимости) затронутого актива** и **тяжести (степени) воздействия** инцидента, с учётом срочности. Часто используют формулу-логику: **Приоритет = f(Влияние × Срочность)** или **Критичность актива × Уровень угрозы**.

Факторы, влияющие на очередность:

- **Ценность и критичность актива** — затронут ли значимый объект КИИ, критичный сервис, конфиденциальные данные; влияние на ключевые бизнес-процессы.
- **Тип и тяжесть воздействия** — что нарушено из триады КЦД: конфиденциальность (утечка), целостность (искажение/шифрование данных), доступность (отказ сервиса).
- **Масштаб распространения** — один хост или вся сеть; есть ли горизонтальное перемещение злоумышленника.
- **Стадия атаки** — только проникновение или уже кража/уничтожение данных (чем дальше по Kill Chain, тем выше приоритет).
- **Наличие и активность угрозы** — продолжается ли атака прямо сейчас.
- **Возможность восстановления** — есть ли резервные копии; обратимы ли последствия.
- **Юридические и регуляторные требования** — инциденты на ЗОКИИ требуют уведомления НКЦКИ в жёсткие сроки (как правило, не позднее 3 часов для значимых объектов / 24 часов для прочих) — это автоматически повышает срочность.
- **Репутационные и финансовые риски.**

Как это реализуется на практике: строится **матрица приоритетов** (например, «уровень воздействия» по строкам × «срочность/критичность актива» по столбцам), на пересечении — приоритет от низкого до критического (P1–P4 или Low/Medium/High/Critical). Каждому уровню сопоставляют целевое время реакции (SLA): критическим — минуты, низким — часы/дни. Категорирование инцидента происходит на стадии обнаружения/регистрации, а пересматривается по мере уточнения масштаба.

Вывод: очередность реагирования — это не интуиция, а формализованное правило: сначала — инциденты, угрожающие самым ценным активам и наносящие наибольший ущерб, особенно если затронуты значимые объекты КИИ и идёт активная фаза атаки.

Вопрос 10. Угрозы и уязвимости информационных систем

Базовые определения (повторяем из в.2): **угроза** — совокупность условий и факторов, создающих опасность нарушения безопасности информации; **уязвимость** — недостаток (слабость) системы, создающий условия для реализации угрозы. Угроза реализуется **через** эксплуатацию уязвимости. Цель любой угрозы — нарушить одно из свойств **триады КЦД**: **Конфиденциальность**, **Целостность**, **Доступность**.

Классификация угроз (несколько оснований):

- *По источнику:* антропогенные (человек — внешний злоумышленник, инсайдер, ошибки персонала), техногенные (сбои оборудования, ПО), стихийные (пожар, наводнение).
- *По расположению источника:* внешние и внутренние.
- *По намеренности:* преднамеренные (атаки) и непреднамеренные (ошибки, халатность).
- *По нарушаемому свойству:* угрозы конфиденциальности (утечка, перехват), целостности (модификация, подмена), доступности (DoS/DDoS, разрушение).

В России угрозы систематизированы в **Банке данных угроз (БДУ) ФСТЭК** (bdu.fstec.ru) и в **методике оценки угроз ФСТЭК (2021)**, где угроза описывается как «источник угрозы + способ реализации + объект воздействия + последствия».

Классификация уязвимостей:

- *По этапу появления:* уязвимости проектирования (архитектурные ошибки), реализации (ошибки кода, баги), конфигурации/эксплуатации (неправильные настройки, дефолтные пароли, отсутствие обновлений).
- *По типу:* уязвимости ПО, аппаратные, организационные.
- **Дефект безопасности (weakness, bug)** — недостаток ПО; эксплуатируемый дефект становится **уязвимостью (vulnerability)**, реализация которой составляет угрозу.

Реестры и системы описания уязвимостей (очень любят спрашивать):

- **CVE** (Common Vulnerabilities and Exposures, MITRE) — список известных уязвимостей с уникальными идентификаторами CVE-ID.
- **NVD** (National Vulnerability Database, США) — нацбаза, дополняет CVE оценками и метаданными.
- **CWE** (Common Weakness Enumeration) — словарь **типов** слабостей/дефектов кода (полезен разработчику).
- **CVSS** (Common Vulnerability Scoring System) — система балльной оценки опасности уязвимости (0–10).
- **CPE** (Common Platform Enumeration) — система идентификации продуктов/платформ.
- **CAPEC** (MITRE) — классификация типовых паттернов атак; **OWASP Top 10** — топ угроз веб-приложений; **WASC** — классификация угроз веб.

- **БДУ ФСТЭК** — российский банк данных угроз и уязвимостей; **OVAL** — язык описания и проверки уязвимостей.

Связка для ответа: «уязвимости описываются и каталогизируются (CVE/CWE/CVSS/CPE, БДУ ФСТЭК), угрозы — систематизируются (БДУ ФСТЭК, CAPEC, OWASP); мониторинг ИБ сопоставляет обнаруженные у нас уязвимости с актуальными угрозами и индикаторами компрометации, чтобы оценить реальный риск».

Вопрос 11. Сетевые атаки: виды, особенности и этапы реализации

Что такое сетевая атака: воздействие на информационную систему через сеть с целью нарушения её безопасности (КЦД). Атака — это «событие или совокупность событий, рассматриваемых как попытка противоправного/деструктивного информационного воздействия».

Виды сетевых атак (классификация):

- **Разведывательные (reconnaissance):** сканирование портов и сервисов, инвентаризация сети, сбор данных (например, через Nmap), OSINT.
- **Атаки доступа/проникновения:** эксплуатация уязвимостей (эксплойты), подбор паролей (brute-force, словарные атаки), перехват учётных данных.
- **Атаки «человек посередине» (MitM):** перехват и подмена трафика (ARP-spoofing, DNS-spoofing, перехват сессий).
- **Атаки на отказ в обслуживании (DoS/DDoS):** перегрузка ресурса множеством запросов, чтобы сделать сервис недоступным.
- **Инъекции и атаки на веб-приложения:** SQL-инъекции, XSS, CSRF, обход аутентификации.
- **Атаки с подменой (spoofing):** подмена IP/MAC/DNS, фишинг.
- **Атаки на сетевые протоколы:** эксплуатация слабостей TCP/IP, перехват, повтор пакетов (replay).
- **Распространение вредоносного ПО и горизонтальное перемещение (lateral movement)** внутри сети.

Особенности реализации: многие современные атаки **многоэтапны и скрытны**, используют легитимные инструменты («living off the land»), шифрование трафика для сокрытия, социальную инженерию для первичного проникновения; целевые атаки (APT) адаптируются под средства защиты жертвы.

Этапы реализации сетевой атаки (обобщённо; перекликается с Cyber Kill Chain — в.13):

22. **Разведка** — сбор информации о цели (сканирование, OSINT).
23. **Получение первоначального доступа** — проникновение через уязвимость, фишинг, украденные учётки.
24. **Закрепление (persistence)** — установка бэкдоров, создание учётки, автозагрузка, чтобы сохранить доступ.

- 25. **Повышение привилегий (privilege escalation)** — получение прав администратора/root.
- 26. **Разведка внутри сети и горизонтальное перемещение** — поиск ценных систем, перемещение по сети.
- 27. **Достижение цели** — кража, искажение или уничтожение данных, шифрование (ransomware), нарушение работы.
- 28. **Соккрытие следов** — очистка логов, маскировка.

Понимание этапов критично для защиты: чем раньше обнаружить атаку (на разведке или первичном доступе), тем меньше ущерб — это и есть идея «разрыва цепочки».

Вопрос 12. Вредоносные программы

Определение: вредоносная программа (ВПО, malware) — программа, предназначенная для несанкционированного воздействия на информацию или ресурсы И(А)С (нарушения КЦД), внедряемая без ведома владельца.

Основные виды (классификация по способу распространения и поведению):

- **Вирусы** — внедряются в файлы/программы и распространяются при их запуске; требуют «носителя».
- **Черви (worms)** — самостоятельно распространяются по сети без участия пользователя, используя уязвимости (пример — Stuxnet, WannaCry).
- **Троянские программы (трояны)** — маскируются под легитимное ПО; не размножаются сами, но открывают доступ/крадут данные.
- **Бэкдоры (backdoor)** — обеспечивают скрытый удалённый доступ к системе.
- **Руткиты (rootkit)** — скрывают присутствие ВПО и злоумышленника в системе (на уровне ОС/ядра).
- **Шпионское ПО (spyware), кейлоггеры** — собирают данные, перехватывают ввод.
- **Программы-вымогатели (ransomware)** — шифруют данные и требуют выкуп (пример — WannaCry, Petya).
- **Рекламное ПО (adware), майнеры (cryptominers)** — навязчивая реклама / скрытый майнинг криптовалюты за счёт ресурсов жертвы.
- **Ботнеты (bots)** — заражённые машины под управлением C2-сервера для DDoS, рассылок и т.д.
- **Загрузчики/дропперы (loader/dropper)** — доставляют и устанавливают другое ВПО.
- **Логические бомбы** — срабатывают при определённом условии.

Классификации/языки описания ВПО: MITRE MAEC (признаки поведения, тип атаки), классификации Kaspersky и Symantec (по способам воздействия). Современное ВПО часто **полиморфно/метаморфно** (меняет код, чтобы обойти сигнатуры), использует обфускацию и упаковку, применяет техники антианализа (обнаружение песочниц).

Как обнаруживают: сигнатурный анализ (по известным шаблонам), эвристический и поведенческий анализ (по подозрительным действиям), анализ в **песочнице** (sandbox — запуск в изолированной среде), сопоставление с **индикаторами компрометации (IoC)** из

Threat Intelligence. Защита: антивирусы/EPP, **EDR/XDR**, песочницы, ограничение запуска (allowlisting).

Вопрос 13. Модель Cyber Kill Chain

Что это: «цепочка поражения» (kill chain) — модель, предложенная компанией **Lockheed Martin**, описывающая целевую кибератаку как последовательность из **7 этапов**. Главная идея заимствована из военной концепции: атака — это цепочка, и **разрыв любого звена срывает всю атаку**. Поэтому защитнику не нужно ловить злоумышленника на последнем шаге — достаточно перехватить его на любом раннем этапе.

Семь этапов Cyber Kill Chain:

29. **Reconnaissance (разведка)** — сбор информации о жертве: какие системы, сотрудники, почтовые адреса, уязвимости. Цель — найти точку входа.
30. **Weaponization (вооружение)** — подготовка «оружия»: создание вредоносной нагрузки (например, заражённый PDF/документ с эксплойтом + бэкдор).
31. **Delivery (доставка)** — доставка оружия жертве: фишинговое письмо, заражённый сайт, USB-носитель.
32. **Exploitation (эксплуатация)** — срабатывание эксплойта: использование уязвимости для выполнения вредоносного кода на системе жертвы.
33. **Installation (установка)** — закрепление: установка ВПО/бэкдора для постоянного доступа (persistence).
34. **Command & Control (C2, управление)** — установление канала связи с сервером управления злоумышленника; теперь атакующий удалённо управляет заражённой системой.
35. **Actions on Objectives (действия по достижению целей)** — собственно цель атаки: кража данных (экспфильтрация), шифрование, уничтожение, горизонтальное перемещение.

Как используют модель: на каждый этап сопоставляют **меры защиты** (по принципу «обнаружить — заблокировать — нарушить — деградировать — обмануть»). Например: на разведке — мониторинг сканирований; на доставке — антиспам и фильтрация почты; на эксплуатации — патчинг и EDR; на C2 — блокировка обращений к известным C2 (через TI/IoC); на действиях — DLP и сегментация сети.

Достоинства и ограничения: модель проста, наглядна и хорошо подходит для построения «эшелонированной обороны». Но её критикуют за **линейность** (реальные атаки нелинейны, особенно инсайдерские) и фокус на проникновении извне. Поэтому Kill Chain дополняют **матрицей MITRE ATT&CK** — более детальной, нелинейной базой тактик и техник. Часто их используют вместе: Kill Chain даёт «общую канву» этапов, ATT&CK — «энциклопедию» конкретных приёмов на каждом этапе.

Вопрос 14. SIEM-системы: задачи, алгоритм функционирования, этапы, состав и архитектура, продукты

Что такое SIEM: Security Information and Event Management — класс решений для **сбора, хранения, нормализации и корреляции** событий безопасности от всех источников в инфраструктуре. SIEM — это «мозг» центра мониторинга (SOC). Появился из слияния двух классов: **SEM** (Security Event Management — обработка событий в реальном времени, корреляция, оповещение) и **SIM** (Security Information Management — накопление и анализ исторических данных, отчётность). Отсюда «литературный» перевод SIEM — «система сбора и корреляции событий».

Задачи SIEM (четыре главные):

- 36. **Консолидация и хранение журналов** событий от разных источников (сеть, ОС, приложения, СЗИ) в едином месте — чтобы данные не «затёрлись» и были доступны для расследования.
- 37. **Предоставление инструментов анализа** событий и разбора инцидентов — унификация и визуализация, фильтрация шума, удобный интерфейс.
- 38. **Корреляция и обработка по правилам** — выявление инцидентов из связанных событий (классика: одно «login failed» — ничего, три+ за минуту — попытка подбора).
- 39. **Автоматическое оповещение и инцидент-менеджмент** — генерация алертов, регистрация инцидентов, интеграция с HelpDesk/SOAR.

Алгоритм функционирования (этапы обработки данных) — отвечать по порядку:

- 40. **Сбор данных (collection)** — агенты и коллекторы собирают события из источников (через агенты, syslog, API, NetFlow, удалённые протоколы).
- 41. **Нормализация (normalization)** — приведение событий разных форматов к единой схеме (коллекторы устраняют «проблему синонимов»: deny/drop/discard → одно событие).
- 42. **Фильтрация и агрегация** — отсев незначимых событий, объединение однородных, чтобы снизить объём.
- 43. **Хранение (storage)** — запись в базу/«озеро данных» для оперативного и долгосрочного доступа.
- 44. **Корреляция (correlation)** — применение правил (в простейшем случае формат **RBR — Rule Based Reasoning**: условия, триггеры, счётчики, сценарий действий) для выявления логически связанных цепочек событий; обогащение данными об угрозах (IoC/TI) и сопоставление с уязвимостями.
- 45. **Оповещение и реагирование (alerting)** — формирование алертов, инцидентов, дашбордов; передача в SOAR/HelpDesk.
- 46. **Анализ и отчётность** — расследование, исторический анализ, отчёты (в т.ч. для соответствия требованиям).

Состав и архитектура (компоненты):

- **Агенты (agents)** — собирают журналы на источниках и передают их.
- **Коллекторы (collectors)** — «библиотеки» для понимания формата конкретного источника, выполняют нормализацию.
- **Серверы-коллекторы** — аккумулируют информацию от агентов.
- **Сервер баз данных (хранилище)** — хранит нормализованные события.
- **Сервер (модуль) корреляции** — анализирует события по правилам, выявляет инциденты.
- **Консоль управления и визуализации** — интерфейс аналитика (дашборды, отчёты, разбор инцидентов).

Источники для SIEM: контроль доступа и аутентификация; журналы серверов и рабочих станций; сетевое активное оборудование; IDS/IPS; антивирусы; сканеры уязвимостей; DLP; GRC-системы; системы инвентаризации/asset-management; NetFlow. Выбор источников зависит от критичности систем, достоверности источника, покрытия каналов и решаемых задач.

Продукты на рынке:

- *За рубежом:* IBM QRadar, Splunk, Micro Focus ArcSight (панель HP ArcSight), McAfee ESM, LogRhythm, Securonix, Exabeam.
- *Российские (импортозамещение):* **MaxPatrol SIEM** (Positive Technologies), **KUMA / Kaspersky Unified Monitoring and Analysis Platform** (Лаборатория Касперского), **Ankey SIEM** (Газинформсервис), **KOMRAD Enterprise SIEM** (НПО «Эшелон»), **RuSIEM**, **СёрчИнформ SIEM**.

Особенности и ограничения: SIEM сам **не предотвращает** инциденты — он собирает и анализирует; эффективность зависит от качества источников и правил корреляции. SIEM дорог и требует квалифицированного персонала; установка «как чёрный ящик» без настройки правил — пустая трата бюджета. Современные SIEM усиливают функциями UEBA, интеграцией с EDR/NDR/SOAR и TI.

Вопрос 15. Другие средства мониторинга и управления компьютерными инцидентами

Кроме SIEM, в арсенале SOC множество классов средств. Нужно знать, что каждое делает и чем отличается.

- **IDS/IPS** — обнаружение/предотвращение сетевых вторжений (анализ трафика; в.11, в. лекции). IDS оповещает, IPS блокирует.
- **Межсетевые экраны (firewall/NGFW), WAF** — фильтрация трафика; NGFW добавляет инспекцию приложений и SSL; WAF защищает веб-приложения.
- **EDR (Endpoint Detection and Response)** — мониторинг и реагирование на **конечных точках** (рабочих станциях, серверах): поведенческий анализ, обнаружение сложных угроз, изоляция хоста, откат изменений. Эволюция антивируса.

- **XDR (Extended Detection and Response)** — расширение EDR на всю инфраструктуру (сеть, почта, облако): единый сбор, корреляция и реагирование «из коробки», интеграция с MITRE ATT&CK и TI.
- **SOAR (Security Orchestration, Automation and Response)** — оркестрация и автоматизация реагирования по сценариям (плейбукам); снижает рутину аналитиков. Близкий класс — **IRP (Incident Response Platform)**.
- **UEBA (User and Entity Behavior Analytics)** — анализ поведения пользователей и сущностей с помощью ML, выявление аномалий (например, нетипичный доступ).
- **NTA / NDR (Network Traffic Analysis / Network Detection and Response)** — анализ сетевого трафика на аномалии и атаки, в т.ч. внутри периметра.
- **Песочница (sandbox)** — изолированная среда для запуска и анализа подозрительных файлов/ВПО.
- **Threat Intelligence Platform (TIP)** — агрегация и применение данных киберразведки (IoC, отчёты об APT); примеры — MISP, YETI, ThreatConnect, R-Vision TIP.
- **Сканеры уязвимостей (Nessus, MaxPatrol VM, XSpider, OpenVAS)** — поиск уязвимостей и инвентаризация.
- **DLP (Data Loss Prevention)** — предотвращение утечек конфиденциальной информации.
- **GRC / Asset Management** — учёт активов, рисков, соответствия.
- **Deception (ловушки, honeypot)** — приманки для обмана и раннего обнаружения злоумышленника (например, Xello Deception).
- **Системы защиты от целевых атак (Anti-APT)** — комплексы вокруг песочниц и сетевого анализа (Kaspersky Anti Targeted Attack, PT Sandbox, PT NAD, Group-IB/F.A.C.C.T. Managed XDR).

Идея для ответа: ни одно средство не самодостаточно. Современная защита — **многоуровневая (эшелонированная):** периметр (firewall/IPS) + конечные точки (EDR) + сеть (NDR) + песочница + аналитика (SIEM/UEBA) + автоматизация (SOAR) + знания об угрозах (TI), и всё это объединяет **SOC**. XDR и SOAR — попытки связать «зоопарк» средств в единый процесс.

Вопрос 16. Индикаторы компрометации (IoC): сетевые, хостовые, источники, описание, порядок использования

Определение: индикатор компрометации (Indicator of Compromise, IoC) — это **наблюдаемый признак (артефакт)**, свидетельствующий о возможной компрометации системы или сети. Проще: «улики» присутствия злоумышленника или ВПО, которые можно искать в логах, трафике и на хостах.

Виды IoC.

Сетевые (network-based):

- вредоносные **IP-адреса** и подсети (например, адреса C2-серверов);
- вредоносные **доменные имена** и URL;

- характерные **HTTP-запросы**, User-Agent, паттерны трафика;
- адреса/порты, к которым обращается ВПО; признаки DNS-туннелирования.

Хостовые (host-based):

- **хеши файлов** (MD5, SHA-1, SHA-256) известного ВПО;
- **имена и пути файлов**, подозрительные исполняемые файлы;
- **ключи реестра** Windows (автозагрузка, persistence);
- имена **процессов и служб**, мьютексы (mutex);
- аномалии в учётных записях, запланированные задачи, артефакты в журналах.

Отдельно выделяют более «высокоуровневые» **TTP** (Tactics, Techniques, Procedures) и **IoA** (**Indicators of Attack**) — индикаторы не следов, а самого поведения/намерения атаки (по матрице MITRE ATT&CK). IoC отвечают «что искать как след», IoA — «как распознать действие».

Пирамида боли (Pyramid of Pain, D. Bianco): чем «выше» тип индикатора, тем больнее злоумышленнику его менять — хеши и IP менять легко, а TTP (поведение) — очень трудно. Поэтому детектирование по TTP эффективнее, чем по хешам.

Источники IoC:

- платформы и фиды **Threat Intelligence** (Group-IB/F.A.C.C.T., Kaspersky, Positive Technologies, ESET, FireEye и др.);
- государственные источники: **НКЦКИ/ГосСОПКА, БДУ ФСТЭК**, бюллетени CERT;
- открытые источники (OSINT, MISP, AlienVault OTX, VirusTotal);
- собственные расследования инцидентов; отчёты об APT-группировках.

Форматы описания (стандарты обмена): **STIX** (Structured Threat Information eXpression — язык описания угроз/индикаторов) и **TAXII** (протокол передачи); **OpenIOC**; правила **YARA** (для файлов/памяти) и **Snort/Suricata** (для трафика).

Порядок использования IoC:

47. **Получение** индикаторов из источников (фиды TI, НКЦКИ).
48. **Нормализация и проверка** (актуальность, достоверность, отсеив устаревших).
49. **Загрузка** в средства защиты: SIEM (правила корреляции), IDS/IPS, EDR/XDR, межсетевые экраны, песочницы.
50. **Поиск (matching)** — сопоставление текущих и исторических событий/трафика с IoC; ретроспективный поиск (не встречался ли индикатор раньше).
51. **Реагирование** при совпадении: блокировка IP/домена, изоляция хоста, расследование.
52. **Обогащение и обмен** — добавление своих находок в TI, обмен с ГосСОПКА/сообществом.

Главная мысль: IoC — это «топливо» для всех систем мониторинга; именно через сопоставление событий с IoC SIEM/EDR превращают поток данных в обнаруженные атаки.

Вопрос 17. Жизненный цикл индикатора компрометации, актуальность

Зачем вопрос: IoC не вечны. Злоумышленник меняет инфраструктуру (IP, домены, хеши), и «протухший» индикатор перестаёт ловить угрозу, но при этом может давать **ложные срабатывания** (например, IP переназначен легитимному сервису). Поэтому IoC имеют жизненный цикл и параметр актуальности.

Жизненный цикл IoC (этапы):

53. **Появление/создание** — индикатор выявляется при расследовании инцидента, анализе ВПО в песочнице или поступает из фида TI.
54. **Описание и обогащение** — индикатору добавляют контекст: тип, связанная угроза/группировка, уровень доверия (confidence), TTL (время жизни), ссылки на отчёты. Оформляют в формате STIX/OpenIOC.
55. **Распространение (sharing)** — публикация и передача потребителям (в SIEM, EDR, партнёрам, ГосСОПКА).
56. **Использование (детектирование)** — загрузка в средства защиты, активный и ретроспективный поиск совпадений.
57. **Оценка эффективности** — насколько индикатор реально срабатывает, сколько даёт ложных позитивов.
58. **Устаревание/деактивация (retirement)** — по истечении актуальности индикатор помечается устаревшим или удаляется, чтобы не порождать ложные срабатывания.

Актуальность индикатора определяется:

- **сроком жизни (TTL)** — у разных типов он разный: вредоносные **IP/домены** живут недолго (часы–дни–недели, их легко сменить), **хеши файлов** — дольше (но обходятся полиморфизмом), а **ТТР/поведенческие индикаторы** — самые «долгоживущие» (их трудно изменить);
- **уровнем доверия (confidence)** источника;
- **контекстом** (связь с активной кампанией);
- **частотой подтверждения** в реальных срабатываниях.

Практический вывод: индикаторы нужно **регулярно обновлять и «состаривать»** (lifecycle management в TIP): свежие фиды повышают обнаружение, а своевременное удаление устаревших снижает шум и ложные срабатывания. Ставка на устойчивые индикаторы (ТТР по MITRE ATT&CK) даёт более долговечное обнаружение, чем погоня за быстро меняющимися хешами и IP (см. «пирамиду боли»).

Вопрос 18. Особенности ОС Windows, используемые злоумышленниками

Идея вопроса: какие архитектурные особенности и механизмы Windows злоумышленники используют для проникновения, закрепления и развития атаки. Знание этого помогает искать следы.

Особенности и механизмы, эксплуатируемые атакующими:

- **Системный реестр (Registry)** — централизованная база настроек. Используется для **закрепления (persistence)**: ключи автозагрузки (`Run`, `RunOnce`), службы, параметры входа. Аналитик ищет там аномалии.
- **Службы (Services) и запланированные задачи (Task Scheduler)** — позволяют запускать ВПО автоматически и с системными правами; популярный способ persistence.
- **PowerShell, WMI, WSH** — мощные легитимные инструменты администрирования. Атакующие применяют технику **«living off the land» (LOLBins)** — используют штатные средства Windows (powershell.exe, wmic.exe, mshta.exe, rundll32.exe, certutil.exe) вместо «своего» ВПО, чтобы не попасться антивирусу.
- **Механизмы аутентификации и SSO**: хранение хешей паролей и билетов в памяти процесса **LSASS** делает возможными атаки **Pass-the-Hash, Pass-the-Ticket, Mimikatz, Kerberoasting** — кражу учётных данных и билетов Kerberos.
- **Active Directory (домен)** — компрометация контроллера домена даёт контроль над всей сетью; атаки на Kerberos (Golden/Silver Ticket).
- **UAC (User Account Control)** и механизмы повышения прав — обходятся (UAC bypass) для эскалации привилегий.
- **DLL-механизмы: DLL hijacking / DLL side-loading** — подмена библиотек, чтобы внедрить код в легитимный процесс; **process injection / process hollowing** — внедрение кода в чужой процесс для маскировки.
- **Альтернативные потоки данных (ADS) в NTFS** — скрытие данных/ВПО внутри файлов.
- **Доступ по умолчанию и распространённость** — Windows самая массовая ОС, под неё больше всего эксплойтов и ВПО; типичные слабости — непропатченные системы, открытые SMB/RDP, слабые пароли, избыточные права.

Вывод: злоумышленник стремится использовать **встроенные средства Windows** (реестр, службы, PowerShell, WMI, LSASS, AD), чтобы слиться с нормальной активностью. Поэтому расследование в Windows — это поиск **аномального использования легитимных механизмов**.

Вопрос 19. Журнал аудита Windows и системный реестр: использование при расследовании инцидентов

Часть А. Журнал аудита (Windows Event Log).

Windows ведёт **журналы событий** — главный источник для расследования. Основные журналы: **Security** (события безопасности — входы, доступ, изменения), **System** (системные события, службы, драйверы), **Application** (приложения), а также специализированные (PowerShell, Sysmon, Task Scheduler). Хранятся в файлах `.evt` (каталог `%SystemRoot%\System32\winevt\Logs\`), просматриваются через **Event Viewer** (`eventvwr.msc`) или PowerShell (`Get-WinEvent`, `wevtutil`).

Ключевые Event ID (полезно назвать на зачёте):

- **4624** — успешный вход в систему; **4625** — неуспешный вход (множество подряд = подбор пароля).
- **4634 / 4647** — выход из системы; **4648** — вход с явным указанием учётных данных.
- **4672** — вход с административными привилегиями.
- **4720** — создана учётная запись; **4722/4725** — включена/отключена; **4726** — удалена; **4728/4732/4756** — добавление в привилегированные группы.
- **4688** — создан новый процесс (важнейшее для обнаружения запуска ВПО); **4697** — установлена служба.
- **4698** — создана запланированная задача.
- **1102** — **очистка журнала аудита Security** (классический признак заметания следов!).
- **4768/4769/4771** — события Kerberos (запросы билетов; полезно при атаках на AD).

Порядок использования при расследовании: определить временные рамки инцидента → собрать журналы с затронутых хостов (включая контроллер домена) → искать аномальные входы (4625, нетипичное время/источник), создание учётки и повышение прав (4720, 4672, 4728), запуск подозрительных процессов (4688), установку служб/задач (4697, 4698), факты очистки логов (1102) → выстроить **таймлайн** действий злоумышленника → сопоставить с IoC. Важно: журналы по умолчанию ограничены по объёму и **могут быть затёрты или очищены** — поэтому их централизованно собирают в SIEM, а аудит включают политиками заранее (это часть стадии подготовки).

Часть Б. Системный реестр Windows (Registry).

Реестр — иерархическая база данных настроек ОС, оборудования, ПО и пользователей. Состоит из корневых разделов (**ульев, hives**): **HKLM** (HKEY_LOCAL_MACHINE — настройки системы), **HKCU** (текущий пользователь), **HKU**, **HKCR**, **HKCC**. Физически хранится в файлах-ульях (`SYSTEM`, `SOFTWARE`, `SAM`, `SECURITY`, `NTUSER.DAT`).

Почему важен для расследования: реестр — кладёз артефактов закрепления и активности:

- **Автозагрузка / persistence:** `HKLM\...\CurrentVersion\Run`, `RunOnce`, `HKCU\...\Run`, ключи служб (`HKLM\SYSTEM\CurrentControlSet\Services`), `Winlogon`, `Image File Execution Options` (подмена отладчика).
- **Следы запуска программ:** **UserAssist**, **ShimCache (AppCompatCache)**, **AmCache** — показывают, какие программы запускались (даже удалённые).

- **Подключённые устройства:** `USBSTOR` — история подключения USB-носителей (важно при утечках).
- **Сетевые подключения, недавние документы (RecentDocs), MRU-списки** — активность пользователя.
- **Учётные записи:** улей **SAM** (хеши локальных паролей — цель атак).

Порядок использования: анализируют ключи автозагрузки и служб на предмет неизвестных/подозрительных записей, сопоставляют пути и хеши с IoC, восстанавливают историю запуска ПО и подключения устройств, строят таймлайн. Инструменты: **Regedit**, **Autoruns** (Sysinternals — показывает все точки автозапуска), **RegRipper**, средства форензики (FTK, Autopsy).

Вопрос 20. Возможности повышения привилегий пользователей в ОС Windows (Privilege Escalation)

Что это: повышение привилегий (privilege escalation) — получение злоумышленником **более высоких прав**, чем были изначально (от обычного пользователя к администратору/SYSTEM, или от рядового доменного аккаунта к администратору домена). Это ключевой этап атаки (см. этапы в в.11): без высоких прав злоумышленник ограничен.

Виды эскалации:

- **Вертикальная** — повышение уровня прав (user → admin → SYSTEM).
- **Горизонтальная** — получение прав другого пользователя того же уровня (доступ к чужим данным).

Основные техники повышения привилегий в Windows:

- **Эксплуатация уязвимостей ядра/ОС и ПО** — использование непропатченных уязвимостей (kernel exploits) для получения SYSTEM.
- **Обход UAC (UAC bypass)** — использование легитимных автоэлевлируемых процессов и ошибок конфигурации для запуска кода с повышенными правами.
- **Кража учётных данных:** дампы памяти **LSASS** (Mimikatz), извлечение хешей из SAM, **Pass-the-Hash / Pass-the-Ticket**, **Kerberoasting** (получение и взлом билетов сервисных учёток), **Golden/Silver Ticket** (подделка билетов Kerberos в AD).
- **Ошибки конфигурации служб:** службы с правами SYSTEM и слабыми правами на исполняемый файл/путь (**unquoted service path**, слабые ACL, возможность изменить бинарь службы), автозапуск с повышенными правами.
- **Злоупотребление привилегиями (privileges/tokens):** наличие опасных привилегий (`SeImpersonatePrivilege`, `SeDebugPrivilege`) → атаки типа **Potato** (**JuicyPotato/PrintSpoofer**) — имперсонация токена SYSTEM.
- **DLL hijacking / подмена путей** — внедрение своей DLL в привилегированный процесс.
- **Запланированные задачи и AlwaysInstallElevated** — установка MSI с правами SYSTEM при некорректной групповой политике.

- **Слабые ACL на ключи реестра и файлы автозагрузки.**

Как обнаруживают/защищаются: мониторинг событий 4672 (вход с привилегиями), 4688 (запуск процессов), аномальной активности LSASS, использования mimikatz-подобных инструментов (EDR); принцип **наименьших привилегий** (least privilege), своевременный патчинг, защита LSASS (Credential Guard), контроль конфигурации служб, ограничение прав администраторов, многофакторная аутентификация. Для аналитика признаки эскалации — внезапное появление прав администратора у обычного пользователя, запуск инструментов дампа учёток, создание привилегированных учёток.

Вопрос 21. Основные процессы ОС Windows и возможные признаки их компрометации

Зачем: аналитик должен знать, как выглядят **нормальные** системные процессы Windows (их имя, родитель, путь, количество, пользователь), чтобы заметить **аномалии** — замаскированное ВПО часто притворяется системным процессом.

Ключевые системные процессы и их «норма»:

- **System (PID 4)** — ядро; один экземпляр, без родительского процесса в обычном смысле.
- **smss.exe** (Session Manager) — запускается из System; первый пользовательский процесс; обычно 1, путь `System32`.
- **csrss.exe** (Client/Server Runtime) — по одному на сессию (обычно 2), родитель — smss (который уже завершился), путь `System32`.
- **wininit.exe** — запускает службы в сессии 0; один экземпляр.
- **services.exe** (Service Control Manager) — **единственный**; родитель — wininit; запускает службы; путь `System32`.
- **lsass.exe** (Local Security Authority) — **единственный**; родитель — wininit; отвечает за аутентификацию и хранит учётные данные → **главная цель атак** (дамп памяти).
- **svchost.exe** — хост-процессы служб; их **много** (нормально), родитель — services.exe, всегда с ключом `-k`, путь `System32`.
- **winlogon.exe** — вход в систему; **explorer.exe** — рабочий стол/оболочка (родитель — userinit, обычно по одному на пользователя).
- **lsaiso.exe** — при включённом Credential Guard.

Признаки компрометации процессов (на что смотреть):

- **Неверный путь:** системный процесс запущен **не из** `C:\Windows\System32` (например, `svchost.exe` из `C:\Users\...\Temp` — почти точно ВПО).
- **Неверный родитель:** например, `lsass.exe`, порождённый не `wininit.exe`; или `svchost.exe` не от `services.exe`.
- **Опечатки в имени (маскировка/тайпсквоттинг):** `scvhost.exe`, `lsas.exe`, `svch0st.exe`, `csrsss.exe` — попытка выглядеть как системный.

- **Неверное число экземпляров:** несколько `lsass.exe` или `services.exe` (норма — один).
- **Аномальный пользователь/права:** системный процесс под обычным пользователем.
- **Подозрительные дочерние процессы:** офисные приложения (winword.exe, excel.exe) или браузер, порождающие `cmd.exe`/`powershell.exe` — признак эксплуатации.
- **svchost.exe без ключа `-k`**, отсутствие цифровой подписи, аномальные сетевые соединения процесса.
- **Process injection / hollowing:** легитимный процесс выполняет несвойственный код (обнаруживается EDR по поведению).

Инструменты: **Process Explorer** и **Process Monitor** (Sysinternals), **Task Manager**, **Autoruns**, EDR-агенты, Sysmon (Event ID 1 — создание процесса с хешем и родителем). Подход аналитика: сравнить дерево процессов с эталоном «нормы», проверить пути, подписи, родителей и сетевую активность, сопоставить хеши с IoC.

Вопрос 22. Особенности ОС Linux: файловая система, управление правами, основные команды

Общие особенности Linux: открытая UNIX-подобная ОС; широко используется на серверах, в облаках, IoT, АСУ ТП. Принципы: «всё есть файл», многопользовательность, модульность, мощная командная строка (shell). Из-за распространённости на серверах — частая цель атак (веб-серверы, SSH).

Файловая система (ФС):

- Единое **дерево каталогов** с корнем `/` (нет «дисков C:/D:» как в Windows). Стандарт **FHS (Filesystem Hierarchy Standard)**.
- Ключевые каталоги: `/` (корень), `/bin`, `/sbin` (исполняемые), `/etc` (конфигурации, в т.ч. `/etc/passwd`, `/etc/shadow`), `/home` (домашние каталоги пользователей), `/root` (домашний root), `/var` (изменяемые данные, `/var/log` — логи!), `/tmp` (временные файлы — частое место ВПО), `/proc` и `/sys` (виртуальные ФС с информацией о процессах и ядре), `/dev` (устройства), `/usr` (программы и данные пользователей), `/boot` (загрузчик и ядро).
- Типы ФС: ext4 (основная), xfs, btrfs и др.
- «Всё есть файл»: устройства, процессы, сокеты представлены как файлы.

Управление правами доступа:

- У каждого файла есть **владелец (user)**, **группа (group)** и **остальные (others)**, и три права для каждого: **r** (read/чтение), **w** (write/запись), **x** (execute/выполнение). Запись вида `rwxr-xr--` или восьмеричная `754`.
- Команды: **chmod** (изменить права), **chown** (сменить владельца), **chgrp** (сменить группу), **umask** (маска прав по умолчанию).
- **Суперпользователь root (UID 0)** — полные права; повышение прав — через **sudo** и **su**.
- Специальные биты: **SUID** (запуск от имени владельца файла — частый вектор эскалации, если стоит на лишнем бинарях), **SGID**, **sticky bit** (на `/tmp`).
- Расширенно: **ACL** (`getfacl`/`setfacl`), мандатный контроль **SELinux / AppArmor**, **capabilities** (тонкие привилегии вместо полного root).

Основные команды (минимум для зачёта):

- Навигация и файлы: `ls`, `cd`, `pwd`, `cp`, `mv`, `rm`, `mkdir`, `find`, `locate`, `cat`, `less`, `head`, `tail`.
- Права/владелец: `chmod`, `chown`, `chgrp`, `sudo`, `su`.
- Процессы: `ps` (`ps aux`), `top`/`htop`, `kill`, `pstree`, `lsof` (открытые файлы), `nice`.
- Сеть: `ip a`/`ifconfig`, `ss`/`netstat`, `ping`, `traceroute`, `curl`/`wget`, `iptables`/`nftables`, `tcpdump`.
- Пользователи: `who`, `w`, `last`, `id`, `whoami`, `useradd`/`usermod`.
- Текст/поиск: `grep`, `awk`, `sed`, `sort`, `uniq`, `wc`.
- Службы/логи: `systemctl`, `journalctl`, `dmesg`.

Вопрос 23. Обнаружение признаков компьютерных инцидентов в ОС Linux: анализ логов, мониторинг активности, обнаружение следов атак и вредоносных процессов

Это «обзорный» вопрос по форензике Linux; детали — в вопросах 24–26. Отвечать по трём направлениям.

1) Анализ логов и событий безопасности. Основные журналы в `/var/log`:

- `/var/log/auth.log` (Debian/Ubuntu) или `/var/log/secure` (RHEL/CentOS) — аутентификация, sudo, SSH-входы (успешные и неуспешные).
- `/var/log/syslog` / `/var/log/messages` — общесистемные события.
- `/var/log/kern.log` — события ядра; `/var/log/dmesg` — загрузка.
- Журналы сервисов: `/var/log/apache2`, `/var/log/nginx` (веб), `/var/log/mysql` и т.д.
- **systemd journal** (`journalctl`) — бинарный централизованный журнал.
- Учёт входов: `/var/log/wtmp` (`last`), `/var/log/btmp` (`lastb` — неудачные входы), `/var/log/lastlog` (`lastlog`).

Признаки атаки в логах: множество неудачных SSH-входов (brute-force), вход с нетипичных IP/времени, всплеск sudo, создание пользователей, ошибки веб-сервера (попытки инъекций), очистка/обнуление логов.

2) Мониторинг активности (в реальном времени):

- **Процессы:** `ps aux`, `top`/`htop`, `pstree` — искать неизвестные процессы, высокую нагрузку CPU (майнеры), процессы из `/tmp`, `/dev/shm`, процессы без бинаря на диске.
- **Сеть:** `ss -tulpn` / `netstat`, `lsof -i` — подозрительные слушающие порты и исходящие соединения (C2), `tcpdump` для анализа трафика.
- **Открытые файлы:** `lsof` — что открыто процессом.
- **Автозапуск и задачи:** `crontab -l`, `/etc/cron*`, systemd-юниты, `/etc/rc.local` — persistence.
- **Пользователи онлайн:** `who`, `w`, `last`.

3) Обнаружение следов атак и вредоносных процессов:

- Поиск изменённых/новых файлов: `find / -mtime -1` (изменённые за сутки), `find / -perm -4000` (SUID-файлы — потенциальная эскалация), файлы в `/tmp`, `/dev/shm`.
- Проверка целостности: **AIDE/Tripwire**, сравнение хешей с эталоном; контроль изменений в системных бинарях (признак руткита).
- Анализ истории команд: `~/.bash_history` (может быть очищен/перенаправлен в `/dev/null` — само по себе признак).
- Обнаружение руткитов: **rkhunter**, **chkrootkit**; аномалии в `/proc` (скрытые процессы).
- Антивирус **ClamAV**, сопоставление с IoC (хеши, YARA-правила), анализ автозагрузки и модулей ядра (`lsmod` — подозрительные kernel-модули).

Вопрос 24. Анализ журналов ОС Linux

Здесь подробнее по работе с логами (часть в.23, но с акцентом на **методику анализа**).

Где лежат логи: каталог `/var/log` (текстовые) и **systemd journal** (бинарный, читается через `journalctl`).

Ключевые файлы и что в них искать:

- **auth.log / secure** — входы по SSH (`sshd`), использование `sudo`/`su`, создание пользователей. Brute-force виден как серия `Failed password`; успешный взлом — `Accepted password/publickey` после серии неудач.
- **syslog / messages** — общие события, запуск/остановка служб, ошибки.
- **wtmp/btmp/lastlog** — история входов: `last` (успешные сессии и перезагрузки), `lastb` (неудачные), `lastlog` (последний вход каждого).
- **Логи веб-серверов** (`access.log`, `error.log`) — обращения, коды ответов, попытки SQL-инъекций/обхода путей, аномальные User-Agent.
- **journalctl** — `journalctl -u ssh`, `journalctl --since`, фильтрация по сервису/времени.

Инструменты и приёмы анализа:

- Утилиты: `grep` (поиск шаблонов: `grep "Failed password" /var/log/auth.log`), `awk`, `sed`, `cut`, `sort | uniq -c | sort -nr` (подсчёт частот, например топ атакующих IP), `tail -f` (наблюдение в реальном времени), `zcat/zgrep` (для архивных `.gz`).
- Построение **таймлайна**: упорядочивание событий по времени, корреляция между разными журналами.
- Централизация: пересылка логов в **SIEM** (через `rsyslog/syslog-ng`, агенты `Wazuh/Filebeat`) — чтобы их нельзя было затереть локально и можно было коррелировать.

Важные нюансы для расследования:

- **Ротация логов** (`logrotate`) — старые логи архивируются/удаляются; нужно учитывать глубину хранения.
- **Подделка/удаление логов** — злоумышленник может очистить или отредактировать локальные логи; защита — отправка логов на отдельный лог-сервер, неизменяемое хранилище, контроль целостности.
- **Время** — следить за часовым поясом и синхронизацией NTP при построении таймлайна.

Вывод: анализ журналов Linux = знать, **какой файл за что отвечает**, уметь **искать признаки** (неудачные входы, новые пользователи, аномальный `sudo`, чистка логов) и **строить таймлайн**, по возможности централизуя сбор в SIEM.

Вопрос 25. Подсистема аудита ОС Linux: состав, порядок использования

Что это: Linux Audit (auditd) — штатная подсистема аудита Linux, позволяющая детально регистрировать события безопасности на уровне ядра: системные вызовы, доступ к файлам, выполнение команд, изменения конфигурации, действия пользователей. Это «глубокий» аудит, дополняющий обычные логи `/var/log`. Реализована на основе **audit-механизма в ядре Linux**.

Состав (компоненты) подсистемы аудита:

- **Ядро (kernel audit subsystem)** — генерирует события аудита на основе правил.
- **auditd** — демон аудита в пространстве пользователя; принимает события от ядра и пишет их в журнал.
- **Журнал аудита** — файл `/var/log/audit/audit.log` (формат «ключ=значение»).
- **Правила аудита** — `/etc/audit/audit.rules` и `/etc/audit/rules.d/`; задаются утилитой **auditctl**.
- **Конфигурация демона** — `/etc/audit/auditd.conf`.
- **Утилиты анализа:**
 - **auditctl** — управление правилами в реальном времени (добавить/просмотреть/удалить).
 - **ausearch** — поиск событий в журнале по критериям (пользователь, время, тип, ключ).
 - **aureport** — формирование сводных отчётов (по входам, командам, аномалиям).
 - **autrace** — трассировка отдельного процесса.

Что можно аудировать (примеры правил):

- Доступ/изменение критичных файлов: например, слежение за `/etc/passwd`, `/etc/shadow` (`-w /etc/passwd -p wa -k passwd_changes`).
- Выполнение системных вызовов (открытие файлов, изменение прав, монтирование).
- Запуск команд определёнными пользователями; использование `sudo`.
- Изменения сетевой конфигурации, загрузка модулей ядра.

Каждое правило помечается **ключом (-k)**, по которому потом удобно искать через `ausearch -k имя_ключа`.

Порядок использования (методика):

59. Установить и запустить демон (`auditd`), включить в автозагрузку.
60. Настроить **правила** (`auditctl` / файлы правил) под задачи — какие объекты и действия отслеживать.
61. Демон пишет события в `/var/log/audit/audit.log`.
62. Анализ: **ausearch** (поиск по ключу/пользователю/времени), **aureport** (отчёты), интеграция с SIEM.

63. При расследовании — выборка событий, относящихся к инциденту (кто, когда, что сделал с критичным файлом/процессом), построение таймлайна.

Зачем нужен на практике: auditd даёт **юридически значимую, детальную** запись действий, которой нет в обычных логах; помогает доказать факт несанкционированного доступа, отследить действия инсайдера, выполнить требования стандартов (в т.ч. для значимых объектов КИИ). Часто связывается с правилами на базе **MITRE ATT&CK** и пересылается в SIEM/Wazuh.

Вопрос 26. Дополнительные артефакты признаков компрометации в ОС Linux

Помимо логов и auditd, при расследовании в Linux анализируют **множество дополнительных артефактов**. Их полезно перечислить по группам.

Артефакты пользователей и аутентификации:

- `/etc/passwd`, `/etc/shadow`, `/etc/group` — учётные записи; искать новые/подозрительные аккаунты, аккаунты с UID 0 (кроме root — признак бэкдора), пустые пароли.
- `/etc/sudoers`, `/etc/sudoers.d/` — кто имеет sudo (несанкционированное расширение прав).
- `~/.ssh/authorized_keys` — добавленные публичные ключи SSH (частый способ закрепления!), `~/.ssh/known_hosts`.
- **История команд:** `~/.bash_history`, `~/.zsh_history` (и факт их обнуления/ссылка на `/dev/null`).

Артефакты закрепления (persistence):

- **cron:** `crontab -l`, `/etc/crontab`, `/etc/cron.d`, `/etc/cron.{hourly,daily,...}` — задачи автозапуска ВПО.
- **systemd-юниты:** `/etc/systemd/system/`, `/lib/systemd/system/` — подозрительные службы.
- **Скрипты автозагрузки:** `/etc/rc.local`, `/etc/profile`, `~/.bashrc`, `~/.profile` — внедрённые команды.
- **Модули ядра:** `lsmod`, `/etc/modules` — руткиты уровня ядра (LKM).
- **Переменные/preload:** `/etc/ld.so.preload`, `LD_PRELOAD` — подмена библиотек (userland-руткиты).

Файловые и процессные артефакты:

- Файлы в `/tmp`, `/dev/shm`, `/var/tmp` — типичные места размещения ВПО и веб-шеллов.
- **SUID/SGID-файлы** в нестандартных местах (`find / -perm -4000`) — векторы эскалации/бэкдоры.
- **Скрытые файлы и каталоги** (начинающиеся с точки), необычные имена.

- **Открытые файлы и удалённые-но-запущенные бинарники:** ``lsOf +L1`` (файл удалён, но процесс работает — признак ВПО).
- **Виртуальная ФС ``/proc``:** ``/proc/<pid>/exe``, ``/proc/<pid>/cmdline``, ``/proc/<pid>/maps`` — что реально запущено (помогает выявить скрытые/безфайловые процессы).
- **Метки времени (timestamps):** `mtime/atime/ctime`; злоумышленники применяют **timestamping** (подделку времени) — несоответствия указывают на манипуляции.

Сетевые артефакты:

- Активные соединения и слушающие порты: ``ss -tulpn``, ``netstat``, ``lsOf -i`` — выявление C2 и веб-шеллов.
- Изменения в ``/etc/hosts``, ``/etc/resolv.conf`` (подмена DNS), правила ``iptables/nftables``.

Прочее: изменения в ``/etc/passwd``-связанных PAM-конфигах (``/etc/pam.d/`` — бэкдор-аутентификация), пакеты и их целостность (``rpm -Va``, ``debsums``), журналы пакетного менеджера (``/var/log/dpkg.log``, ``/var/log/yum.log``).

Вывод: в Linux «улики» рассыпаны по учётным записям, точкам автозапуска, файловой системе (``/tmp``, SUID, ``/proc``), сетевым соединениям и метаданным. Аналитик системно проверяет эти артефакты, сопоставляет с IoC и строит таймлайн компрометации.

Вопрос 27. ГосСОПКА: нормативная база, назначение, состав, порядок представления информации, используемые средства

Что такое ГосСОПКА: Государственная система обнаружения, предупреждения и ликвидации последствий компьютерных атак на информационные ресурсы Российской Федерации. По сути — общенациональная распределённая система центров мониторинга и реагирования (аналог сети SOC/CERT/CSIRT), объединяющая госорганы и владельцев критической инфраструктуры под единой координацией.

Нормативная база функционирования:

- **Указ Президента РФ № 31с (2013)** — о создании ГосСОПКА.
- **Федеральный закон № 187-ФЗ «О безопасности КИИ» (2017)** — правовая основа: обязывает субъектов КИИ подключаться к ГосСОПКА и сообщать об инцидентах.
- **Указ Президента РФ № 620 (2017)** — Положение о ГосСОПКА; **ФСБ России** определена уполномоченным органом, в её структуре действует **НКЦКИ** (Национальный координационный центр по компьютерным инцидентам) — главный координирующий центр.
- **Указ № 250 (2022)** — дополнительные меры по ИБ.
- **Приказы ФСБ России:** № 366 (о НКЦКИ), **№ 367 и № 368 (2018)** — перечень и порядок представления сведений об инцидентах, регламент обмена; **№ 196 (2019)** — требования к техническим средствам ГосСОПКА; № 281, № 282 (2019) — порядок установки средств и информирования НКЦКИ.

Назначение (задачи) ГосСОПКА:

- обнаружение компьютерных атак и инцидентов;
- предупреждение (прогнозирование) угроз и атак;
- ликвидация последствий компьютерных атак;
- реагирование на инциденты;
- установление причин инцидентов, анализ;
- обмен информацией между субъектами КИИ об атаках и инцидентах;
- формирование и поддержание единого фонда данных об угрозах, обеспечение взаимодействия (в т.ч. международного) при реагировании.

Состав (структура центров). ГосСОПКА строится по **ведомственному и территориальному принципу** и включает:

- **Главный центр ГосСОПКА / НКЦКИ** — координирует всю систему, ведёт обмен с субъектами КИИ.
- **Ведомственные центры** — создаются государственными органами; регулируют работу подведомственных и корпоративных сегментов в своей сфере.
- **Корпоративные центры** — создаются владельцами информационных ресурсов, операторами связи, иными организациями (часто это лицензиаты ФСБ/ФСТЭК), которые мониторят свою инфраструктуру.

Субъект КИИ взаимодействует с ГосСОПКА **двумя способами**: (1) напрямую подключаясь к инфраструктуре НКЦКИ; (2) через ведомственный или корпоративный центр (сегмент) ГосСОПКА.

Порядок представления информации об инцидентах (по приказам ФСБ № 367/282):

- субъект КИИ обязан **уведомлять НКЦКИ** о компьютерных инцидентах;
- для инцидентов на **значимых объектах КИИ** срок — **не позднее 3 часов** с момента обнаружения; для прочих — **не позднее 24 часов**;
- передача — через техническую инфраструктуру НКЦКИ (личный кабинет/API на платформе ГосСОПКА), по согласованным форматам;
- состав сведений: дата/время, тип инцидента, затронутые объекты, последствия, технические детали (IP, индикаторы), принятые меры;
- дополнительно осуществляется **двусторонний обмен**: НКЦКИ рассылает бюллетени, индикаторы компрометации и рекомендации.

Используемые средства: к средствам ГосСОПКА относятся технические средства обнаружения, предупреждения, ликвидации последствий атак и реагирования — это **SIEM**, средства обнаружения вторжений (**IDS/IPS**), сканеры уязвимостей, средства анализа трафика (**NTA/NDR**), средства защиты конечных точек (**EDR**), платформы реагирования (**SOAR/IRP**), средства Threat Intelligence (обмен индикаторами), а также средства криптозащиты для защищённого взаимодействия с НКЦКИ. Требования к ним установлены приказом ФСБ № 196 (см. вопрос 28).

Вывод: ГосСОПКА — это «зонтик» государственного уровня над корпоративными SOC: технически опирается на те же классы средств (SIEM, IDS, EDR, SOAR, TI), но добавляет обязательную координацию через НКЦКИ, обязательное информирование об инцидентах в жёсткие сроки и единый обмен данными об угрозах.

Вопрос 28. Требования к техническим средствам ГосСОПКА

Основа: требования установлены **приказом ФСБ России № 196 от 06.05.2019** «Об утверждении Требований к средствам, предназначенным для обнаружения, предупреждения и ликвидации последствий компьютерных атак и реагирования на компьютерные инциденты». Эти средства должны обеспечивать выполнение функций ГосСОПКА (см. в.27).

Функциональные группы средств ГосСОПКА (по назначению):

64. **Средства обнаружения** компьютерных атак — анализ событий и трафика, выявление атак (роль IDS/IPS, SIEM, NTA).
65. **Средства предупреждения** — выявление уязвимостей и предпосылок атак (сканеры уязвимостей, инвентаризация).
66. **Средства ликвидации последствий** компьютерных атак — восстановление, нейтрализация.

67. **Средства реагирования** на инциденты — поддержка процесса реагирования (SOAR/IRP).
68. **Средства обмена информацией (ППКА/взаимодействия с НКЦКИ)** — приём/передача сведений об инцидентах и индикаторах.
69. **Средства криптографической защиты** канала взаимодействия с НКЦКИ.

Основные требования к техническим средствам (что должны обеспечивать):

- **Сбор, обработку, хранение и анализ** информации о событиях ИБ, компьютерных атаках и инцидентах.
- **Поиск признаков** компьютерных атак в сетях электросвязи (по сигнатурам и индикаторам компрометации).
- **Инвентаризацию** информационных ресурсов и **выявление уязвимостей**.
- **Учёт и регистрацию** компьютерных инцидентов, ведение их базы.
- **Информационное взаимодействие с НКЦКИ** — защищённую передачу сведений об инцидентах в установленные сроки и форматах, приём данных об угрозах.
- **Хранение информации** о событиях и инцидентах в течение установленного срока (для расследования и отчётности).
- **Криптографическую защиту** информации при взаимодействии (с использованием сертифицированных СКЗИ).
- **Защиту самих средств** ГосСОПКА от несанкционированного доступа и воздействия.
- **Регистрацию действий** операторов средств (аудит).

Требования к надёжности, эксплуатации и сертификации:

- средства должны быть **работоспособны в непрерывном режиме (24/7)**, обладать отказоустойчивостью;
- размещаться на территории РФ;
- проходить **оценку соответствия** требованиям безопасности (сертификация ФСБ/ФСТЭК, особенно для СКЗИ и средств обнаружения);
- обеспечивать **разграничение доступа**, идентификацию/аутентификацию операторов, защиту от модификации;
- поддерживать **обновление** баз решающих правил, сигнатур и индикаторов компрометации;
- обеспечивать **совместимость форматов** обмена с инфраструктурой НКЦКИ.

Требования к персоналу и организации (сопутствующие): наличие подготовленных специалистов, регламентов реагирования, лицензий ФСБ/ФСТЭК (на деятельность по защите информации и мониторингу) для корпоративных/ведомственных центров.

Вывод: технические средства ГосСОПКА — это не один продукт, а **комплекс** (обнаружение + предупреждение + ликвидация + реагирование + защищённый обмен с НКЦКИ + криптозащита), к которому предъявляются требования по функциональности, непрерывности, защищённости, хранению данных и сертификации. По функциям они совпадают с корпоративным SOC (SIEM, IDS/IPS, сканеры, EDR, SOAR, TI), но с обязательным

защищённым каналом и регламентом взаимодействия с государственным координатором
— НКЦКИ.

ЧАСТЬ III. КРАТКОЕ САММАРИ (ШПАРГАЛКИ ДЛЯ ПОВТОРЕНИЯ)

Эту часть удобно перечитывать перед сном и утром перед зачётом. Каждый пункт — сжатая выжимка ответа: главное, что нужно вспомнить и произнести.

Шпаргалки по вопросам

1. Нормативка. Вертикаль: законы (149-ФЗ, **187-ФЗ** о КИИ, 152-ФЗ) → указы Президента (31с, **620** — ГосСОПКА, 250) → приказы **ФСТЭК** (защита: №235, 239, 31, 17, 21) и **ФСБ/НКЦКИ** (ГосСОПКА: №367, 368, 196) → стандарты **ГОСТ Р 59709–59712-2022** (термины, общие положения, организация, реагирование). ФСТЭК = требования к защите, ФСБ = ГосСОПКА.

2. Понятия. Цепочка: **событие** (факт из лога) → **уязвимость** (слабость) + **угроза** (опасность) → **атака** (вредоносное воздействие) → **инцидент** (состоявшееся нарушение). Меры ЗИ — действия по защите; **компенсирующие меры** — замена базовых при эквивалентной защите. Управление инцидентом — обнаружение+реагирование+ликвидация+анализ.

3. Мониторинг ИБ. Постоянное наблюдение и анализ событий. **Объекты:** АРМ, серверы, телеком-оборудование, технологическое оборудование, СЗИ. **4 уровня:** источники → сбор → хранение/обработка → представление. **Задачи:** сбор, нормализация, фильтрация, агрегация, корреляция, выявление нарушений, контроль защищённости, анализ угроз. **Свойства:** непрерывность, полнота, достоверность, своевременность.

4. События от СЗИ. Источники-СЗИ: МЭ/NGFW (allow/deny), IDS/IPS (атаки, сканы), антивирус/EDR (ВПО, карантин), контроль доступа (входы, привилегии), DLP (утечки), сканеры (уязвимости), WAF (атаки на веб). Это уже «отфильтрованные» сигналы безопасности.

5. События от И(А)С. Штатные средства самой системы: **ОС** (входы 4624/4625, процессы, учётки, очистка логов), **СУБД** (запросы, экспорт), веб/прикладные серверы (логи доступа), сетевое оборудование (конфиг, NetFlow), **AD** (Kerberos). Сырьё о работе инфраструктуры; ценны в корреляции с событиями СЗИ.

6. Стадии управления инцидентами (ГОСТ 59710/59712). (1) **Организация/подготовка** (команда, план, средства, обучение); (2) **Обнаружение и регистрация** (фиксация признаков → подтверждение инцидента); (3) **Реагирование** (масштаб → локализация → последствия → ликвидация → закрытие → фиксация материалов → причины); (4) **Анализ результатов** (накопление опыта → рекомендации → оценка эффективности). Цикл (PDCA), как в ISO 27035.

7. Мероприятия. Подготовка (команда, план, плейбуки, подключение к ГосСОПКА); обнаружение (сбор/корреляция, IoC, регистрация); реагирование (масштаб, сдерживание,

сбор доказательств, ликвидация, уведомление НКЦКИ); анализ (root cause, обновление правил/IoC, рекомендации). Сквозное: документирование, обмен с ГосСОПКА.

8. План реагирования (IRP). Документ «кто/что/когда/как». Структура: назначение → роли и эскалация → классификация инцидентов → обнаружение → процедуры/плейбуки → коммуникации и уведомления (НКЦКИ в срок) → сбор доказательств → восстановление → постанализ → приложения (контакты, чек-листы). «Живой», тестируется на киберучениях; исполнение автоматизирует SOAR.

9. Очередность реагирования. Приоритет = Влияние × Срочность (критичность актива × тяжесть). Факторы: ценность актива, нарушение К/Ц/Д, масштаб, стадия атаки, активность угрозы, возможность восстановления, требования закона (ЗОКИИ → срочно), репутация. Реализуется **матрицей приоритетов P1–P4** с целевым SLA (критич. — минуты).

10. Угрозы и уязвимости. Угроза реализуется через уязвимость; цель — нарушить **КЦД**. Угрозы: по источнику (антропо/техно/стихийные), внутр./внешн., предна-/непреднамеренные. Уязвимости: проектирования/реализации/конфигурации. Реестры: **CVE** (список), **NVD** (база США), **CWE** (типы слабостей), **CVSS** (оценка 0–10), **CPE** (продукты), **CAPEC/OWASP** (атаки/веб), **БДУ ФСТЭК**.

11. Сетевые атаки. Виды: разведка/сканирование, доступ (эксплойты, brute-force), MitM, DoS/DDoS, инъекции (SQLi/XSS), spoofing, ВПО, lateral movement. **Этапы:** разведка → первичный доступ → закрепление → повышение привилегий → внутренняя разведка/перемещение → достижение цели → сокрытие следов. Чем раньше обнаружить — тем меньше ущерб.

12. Вредоносные программы. Вирус (нужен носитель), червь (сам по сети), троян (маскировка), бэкдор (скрытый доступ), руткит (сокрытие), spyware/кейлоггер, **ransomware** (шифровальщик), adware/майнер, ботнет (C2), дроппер/загрузчик. Полиморфизм/обфускация. Обнаружение: сигнатуры, эвристика, поведение, **песочница**, IoC. Классификации: MAEC, Kaspersky, Symantec.

13. Cyber Kill Chain (Lockheed Martin). 7 этапов: **Разведка → Вооружение → Доставка → Эксплуатация → Установка → C2 (управление) → Действия по цели**. Разрыв любого звена срывает атаку → защищаться как можно раньше. Минус — линейность; дополняют матрицей **MITRE ATT&CK** (нелинейная база тактик и техник).

14. SIEM. Сбор и **корреляция** событий (SIM+SEM). **Задачи:** консолидация логов, анализ, корреляция по правилам (RBR), оповещение/инцидент-менеджмент. **Алгоритм:** сбор → нормализация → фильтрация/агрегация → хранение → корреляция → оповещение → отчётность. **Состав:** агенты, коллекторы, серверы-коллекторы, БД, сервер корреляции, консоль. **Продукты:** QRadar, Splunk, ArcSight; РФ — MaxPatrol SIEM, KUMA, Ankey, KOMRAD, RuSIEM. Сам не предотвращает.

15. Другие средства. IDS/IPS, NGFW/WAF, **EDR** (хосты), **XDR** (вся инфраструктура), **SOAR/IRP** (автоматизация реагирования), **UEBA** (поведение), **NTA/NDR** (трафик), **песочница**, **TIP**

(киберразведка), сканеры уязвимостей, DLP, deception/honeypot, Anti-APT. Защита многоуровневая; всё объединяет **SOC**.

16. Индикаторы компрометации (IoC). Признак-«улика» компрометации. **Сетевые:** IP, домены, URL, паттерны трафика, C2. **Хостовые:** хеши (MD5/SHA), файлы, ключи реестра, процессы/службы, mutex. Выше — **TTP/IoA** (поведение, MITRE ATT&CK). «Пирамида боли»: TTP менять труднее всего. Источники: TI-фиды, НКЦКИ, БДУ ФСТЭК, OSINT. Форматы: **STIX/TAXII, OpenIOC, YARA, Snort**. Порядок: получить → проверить → загрузить в SIEM/EDR/IPS → искать (вкл. ретроспективно) → реагировать → обмениваться.

17. Жизненный цикл IoC. Появление → описание/обогащение (контекст, confidence, TTL) → распространение → использование (детект) → оценка эффективности → устаревание/деактивация. **Актуальность** зависит от TTL (IP/домены живут недолго, хеши дольше, TTP — дольше всех), доверия, контекста. Нужно обновлять свежие и «состаривать» устаревшие, чтобы снизить ложные срабатывания.

18. Особенности Windows для атакующих. Реестр (persistence: Run/службы), службы и Task Scheduler, **PowerShell/WMI** и LOLBins («living off the land»), **LSASS** (кража хешей/билетов: Mimikatz, Pass-the-Hash, Kerberoasting), Active Directory (Golden/Silver Ticket), обход UAC, DLL hijacking, process injection/hollowing, NTFS ADS. Атакующий маскируется под штатные механизмы.

19. Журнал аудита и реестр Windows. Event Log (Security/System/Application, файлы .evtx): 4624/4625 (вход/неудача), 4672 (привилегии), 4720 (новая учётка), 4688 (запуск процесса), 4697 (служба), 4698 (задача), **1102 (очистка лога!)**, 4768/4769 (Kerberos). **Реестр** (улики HKLM/HKCU; SYSTEM, SOFTWARE, SAM): автозагрузка (Run/RunOnce/Services), следы запуска (UserAssist, ShimCache, AmCache), USBSTOR. Строить таймлайн, собирать в SIEM (логи затирают). Инструменты: Event Viewer, Autoruns, RegRipper.

20. Повышение привилегий в Windows. Вертикальная (user→admin→SYSTEM) и горизонтальная. Техники: эксплойты ядра, **обход UAC**, кража учёток (LSASS/Mimikatz, Pass-the-Hash/Ticket, Kerberoasting, Golden Ticket), ошибки служб (unquoted path, слабые ACL), опасные привилегии (SeImpersonate → Potato), DLL hijacking, AlwaysInstallElevated. Защита: least privilege, патчинг, Credential Guard, MFA, мониторинг 4672/4688.

21. Процессы Windows и компрометация. Нормы: System(PID4), smss, csrss(×2), wininit, services(1), lsass(1, цель атак), svchost(много, от services, ключ -k), winlogon, explorer. **Признаки компрометации:** неверный путь (не System32), неверный родитель, опечатки (scvhost, lsas), лишние экземпляры lsass/services, офис→cmd/powershell, нет подписи, аномальная сеть, injection. Инструменты: Process Explorer, Autoruns, Sysmon (ID 1).

22. Linux: ФС, права, команды. Единое дерево от `/` (FHS): /etc (конфиги, passwd/shadow), /home, /var/log (логи), /tmp (ВПО), /proc, /bin. Права **rwX** для user/group/others (chmod/chown), **root UID 0**, sudo/su, биты **SUID/SGID/sticky**, SELinux/AppArmor. Команды: ls/cd/find/grep, ps/top/lsof, ss/netstat, who/last/id, systemctl/journalctl.

23. Признаки инцидента в Linux. (1) **Логи** /var/log: auth.log/secure (SSH, sudo, brute-force), syslog/messages, wtmp/btmp (last/lastb). (2) **Мониторинг:** ps/top (майнеры, /tmp), ss/lsof (C2, порты), cron/systemd (persistence). (3) **Следы:** find -mtime/-perm 4000 (SUID), AIDE/Tripwire (целостность), .bash_history, rkhunter/chkrootkit (путкиты), ClamAV, IoC/YARA.

24. Анализ журналов Linux. /var/log + journalctl. auth.log (Failed/Accepted password), wtmp/btmp/lastlog (last/lastb/lastlog), веб-логи (инъекции). Приёмы: grep/awk/`sort|uniq -c|sort -nr` (топ IP), tail -f, таймлайн, централизация в **SIEM** (rsyslog/Wazuh). Учитывать ротацию (logrotate), подделку логов, время (NTP).

25. Подсистема аудита Linux (auditd). Глубокий аудит на уровне ядра. **Состав:** ядро (audit) + демон auditd + журнал /var/log/audit/audit.log + правила (/etc/audit/rules.d, auditctl) + утилиты ausearch (поиск), aureport (отчёты), autrace. Правила с ключом `-k` следят за файлами (passwd/shadow), syscalls, командами. Порядок: запустить → настроить правила → пишет лог → анализ ausearch/aureport → SIEM. Даёт юридически значимую запись действий.

26. Доп. артефакты Linux. Учётки: passwd/shadow/group (UID 0!), sudoers, ~/.ssh/authorized_keys (бэкдор-ключи), .bash_history. Persistence: cron, systemd-юниты, rc.local, .bashrc, модули ядра (lsmod), /etc/ld.so.preload. Файлы: /tmp, /dev/shm, **SUID** (find -perm 4000), скрытые, `lsof +L1` (удалён-но-запущен), /proc/<pid>, timestomping. Сеть: ss/lsof -i, /etc/hosts. ПАМ-бэкдоры, целостность пакетов.

27. ГосСОПКА. Гос. система обнаружения/предупреждения/ликвидации атак. **Нормативка:** Указ 31с, **187-ФЗ**, Указ **620** (ФСБ уполномочена, **НКЦКИ** — координатор), приказы ФСБ 367/368/196. **Назначение:** обнаружение, предупреждение, ликвидация, реагирование, обмен данными об угрозах. **Состав:** Главный центр/НКЦКИ + **ведомственные** + **корпоративные** центры. Подключение: напрямую к НКЦКИ или через сегмент. **Информирование:** ЗОКИИ — **≤3 ч**, прочее — **≤24 ч**, через инфраструктуру НКЦКИ. **Средства:** SIEM, IDS/IPS, сканеры, NTA, EDR, SOAR, TI, СКЗИ.

28. Требования к средствам ГосСОПКА (приказ ФСБ №196). Группы: обнаружение, предупреждение, ликвидация, реагирование, обмен с НКЦКИ, криптозащита. Должны: собирать/хранить/анализировать события и инциденты; искать признаки атак по IoC; инвентаризация и поиск уязвимостей; учёт инцидентов; защищённое взаимодействие с НКЦКИ; хранить данные установленный срок; криптозащита (сертиф. СКЗИ); защита самих средств и аудит операторов. Надёжность 24/7, размещение в РФ, сертификация ФСБ/ФСТЭК, обновляемые сигнатуры/правила, совместимость форматов, обученный персонал и лицензии.

Финальный чек-лист «отличий», которые любят спрашивать

- **IDS vs IPS:** IDS только обнаруживает и оповещает (ставится «сбоку», копия трафика); IPS обнаруживает и **блокирует** (ставится «в разрыв»).

- **SIEM vs SOAR:** SIEM собирает и коррелирует события (обнаружение); SOAR автоматизирует реагирование по плейбукам (оркестрация). SIEM — источник для SOAR.
- **EDR vs XDR:** EDR — только конечные точки; XDR — конечные точки + сеть + почта + облако, единая корреляция и реагирование «из коробки».
- **SIM vs SEM:** SIM — анализ накопленных данных (история, отчёты); SEM — события в реальном времени (корреляция, алерты); вместе = SIEM.
- **Уязвимость vs угроза vs атака vs инцидент:** слабость → опасность → вредоносное воздействие → состоявшееся нарушение.
- **Cyber Kill Chain vs MITRE ATT&CK:** Kill Chain — линейные 7 этапов; ATT&CK — нелинейная энциклопедия тактик и техник.
- **IoC vs IoA:** IoC — след («что было»); IoA — поведение/намерение («что делается»).
- **ФСТЭК vs ФСБ:** ФСТЭК — требования к защите (КИИ, ГИС, ПДн, АСУ ТП); ФСБ/НКЦКИ — ГосСОПКА, реагирование, криптография.

Удачи на зачёте! Сначала называйте определение и суть, затем — структуру/этапы, затем — пример или отличие от похожей системы. Это производит лучшее впечатление и показывает понимание, а не зубрёжку.

